School of Computing and Digital Technology

COMP50003
Cyber Security

Group Assignment
Specification

Module Learning Outcomes for this assignment

1. Demonstrate a critical understanding and critically evaluate fundamentalaspects of Cyber Security

2. Identify risks to the security of Data, Systems and Networks

3. Critically analyse the process by which disaster recovery and risk preventionplans are developed and be able to critically evaluate such plans

GROUP MEMBERS:

THARINDU RATNAYAKE: CB012346
MALEESHA RUPASINGHE : CB013180
RASHEN PERERA: CB014654

Table of Contents

Module Learning Outcomes for this assignment 1
INTRODUCTION 5
Introduction to MediCloud Health 5
Problem statement 5
Purpose of the report 5
Solutions and benefits 5
THREAT ANALYSIS 6
Identification of key assets 6
Identification of potential threats 7
Threat prioritization 14
LAB ARCHITECTURE 16
Lab design principles 16
Lab architecture 16
Virtual machines 17
Network segmentation 18
Security controls 19
Red team (Attack simulator) 19
Tools justification 20
Vulnerability Assessment 20
Penetration Testing 20
Network Monitoring 21
Incident Response 21
ATTACK SIMULATIONS 22
Man In The Middle attack (MITM) 22
Distributed Denial of Service DDoS attack 25
Phishing attack 29
SQL Injection attack 33
Ransomware attack 40
INCIDENCE RESPONSE PLAN 44
Incident Response Team – Roles/ Responsibilities 44
Attack-Specific Response Procedures 44
SQL Injection Attack Response 44
Ransomware Attack Response 45

Phishing Attack Response 45
DDoS Attack Response 46
MITM Attack on IoT Devices 46
Communication Protocol 47
Preparation Activities 47
Post-Incident Activities 48
SECURITY CONTROLS & MITIGATION PLAN 48
PYTHON SCRIPT 51
Explanation 54
Role of the Key 54
Role of the Initialization Vector (IV) 55
Explanation of Block Size 55
Purpose of Padding (PKCS7) 55
Importance of CBC Mode vs. Insecure Modes (like ECB) 55
REFERENCES 55

Table of Figures

Figure 1. Lab architecture 17
Figure 2. MITM flow 22
Figure 3. MITM 1 23
Figure 4. MITM 2 24
Figure 5. DDoS flow 25
Figure 6. DDoS 1 26
Figure 7. DDoS 2 27
Figure 8. DDoS 3 27
Figure 9. DDoS 4 28
Figure 10. Phishing flow 29
Figure 11. Phishing 1 30
Figure 12. Phishing 2 31
Figure 13. Phishing 3 31
Figure 14. Phishing 4 32
Figure 15. Phishing 5 32
Figure 16. SQLI flow 34
Figure 17. SQLI 1 35
Figure 18. SQLI 2 35
Figure 19. SQLI 3 36
Figure 20. SQLI 4 37
Figure 21. SQLI 5 37

Figure 22. SQLI 6 38
Figure 23. SQLI 7 38
Figure 24. Ransome flow 41
Figure 25. Ransomware 1 42
Figure 26. Ransomware 2 42
Figure 27. Ransomware 3 43
Figure 28. AES encryption flow 52
Figure 29. Python script 1 53
Figure 30. Python script 2 53
Figure 31. Running python 54
Figure 32. Encryption results 54

INTRODUCTION

This report presents a comprehensive proposal for the establishment of a Cyber Security Lab at MediCloud Health. In response to the growing frequency and sophistication of cyber threats targeting the healthcare sector, this initiative is designed to proactively strengthen the organization's security posture. The document outlines a detailed threat analysis, a tailored lab architecture for simulating attacks and testing defenses, and actionable plans for mitigation and incident response. Furthermore, it includes a practical demonstration of cryptographic principles central to data protection. The implementation of this lab is recommended as a critical investment to safeguard sensitive patient data, ensure operational continuity, and maintain stakeholder trust in MediCloud's vital services.

Introduction to MediCloud Health

MediCloud Health operates as a dynamic and expanding provider within the healthcare technology sector. Its core services include sophisticated cloud-based Electronic Health Record (EHR) systems and innovative remote patient monitoring tools. These platforms are integral to modern patient care, managing highly sensitive health information and facilitating continuous treatment outside traditional clinical settings. The organization's increasing reliance on its cloud infrastructure and integrated IoT devices underscores its position at the forefront of digital healthcare delivery.

Problem statement

This technological advancement and growth have elevated MediCloud's exposure to the modern cyber threat landscape. The organization is confronting a rising tide of malicious activities, including targeted phishing campaigns, sophisticated ransomware, and persistent attempts at unauthorized data access. The concentration of valuable patient data and the critical nature of its services make MediCloud a high-value target. A significant security incident could lead to severe operational disruption, compromise patient safety, incur substantial financial losses, and critically erode stakeholder trust.

Purpose of the report

To proactively counter these threats, the establishment of a dedicated Cyber Security Lab has been identified as a strategic priority. This report has been commissioned to provide a detailed design and implementation plan for this lab. The central objective is to present a controlled environment that accurately replicates MediCloud's operational network, thereby enabling rigorous security testing, vulnerability assessment, and the enhancement of defensive capabilities without risk to live systems.

Solutions and benefits

The proposed solution provides the construction of an isolated lab architecture, integrated with a suite of industry-recognized security tools for both offensive simulation and defensive monitoring. The primary benefits of this initiative are multifaceted: it will empower MediCloud to proactively identify and remediate vulnerabilities, validate the efficacy of existing security controls, and provide a practical training ground for incident response teams. Ultimately, this investment is designed to fortify the organization's cyber resilience, ensure business continuity,

and safeguard its reputation in an increasingly hostile digital environment.

THREAT ANALYSIS

Identification of key assets

Asset Type	Asset	Potential Risk
Hardware	Cloud server	A DDoS attack could strain these servers, causing service downtime and making digital records inaccessible, directly impacting patient care.
	IoT medical devices	A Man-in-the-Middle (MITM) attack could intercept from these devices to the cloud, this can lead to various disasters like incorrect patient treatment plans or diagnoses.
	Mobile devices/ workstations	An employee falling for a phishing attack could lead the health sector to go through certain ransomware or something much worse like leaking critical data.
Software & Data	Health record database	A SQL Injection attack on a web portal or a direct breach could lead to mass exfiltration of sensitive patient data.
	Web applications	A vulnerability in the web application could be exploited for unauthorized access, allowing an attacker to view or manipulate patient records.
	Payment processing systems	If a vulnerability is found to exploit patient payment card information, payment fraud could occur.
People	Clinical staff/ doctors	An insider threat, can be intentional or unintentional, leaking patient details or accessing malicious websites could harm the system.
	System admins/ board members	Excessive privileges or misconfiguration by an admin could accidentally expose sensitive systems to the internet.

Identification of potential threats

Allegro worksheet for phishing attack

Allegro - Worksheet 10	INFORMATION ASSET RISK WORKSHEET		
Information Asset Risk — Threat	Information Asset	Workstation, email systems, user credentials	
	Area of Concern	Unauthorized access and data breach	
	(1) Actor *Who would exploit the area of concern or threat?*	Cyber criminals	
	(2) Means *How would the actor do it? What would they do?*	Send deceptive emails that appear to be from a trusted source, containing malicious links or attachments.	
	(3) Motive *What is the actor's reason for doing it?*	To steal employee login credentials, leak patient information	
	(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**	
	(5) Security Requirements *How would the information asset's security requirements be breached?*	Intentionally or unintentionally leaking of user credentials or having vulnerabilities in the system	
	(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium** ❑ **Low**

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
	Impact Area	**Value**	**Score**
Data breach leading to loss of patient trust. Financial loss from regulatory fines and incident response costs.	Reputation & Customer Confidence	8	4
	Financial	8	4
Downtime and effort required to contain the breach, reset credentials. Potential for misdiagnosis.	Productivity	5	2.5
	Safety & Health	6	3
Fines for data protection violations.	Fines & Legal Penalties	8	4

Relative Risk Score	17.5

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
❑ Accept	❑ Defer	❑ Mitigate	❑ Transfer

For the risks that you decide to mitigate, perform the following:	
On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
Email gateways, workstations, user accounts	**Administrative** Mandatory, regular security awareness training and phishing simulations. **Technical** Advanced email filtering, multi-factor authentication (MFA) on all accounts, endpoint detection and response (EDR) software. **Physical** Securing workstations when not in use. What residual risk would still be accepted by the organization? The risk of a highly sophisticated, targeted phishing attack bypassing all technical controls and tricking a trained user.

Allegro worksheet for ransomware attack

Allegro - Worksheet 10			INFORMATION ASSET RISK WORKSHEET
Information Asset Risk		Information Asset	Database servers, file shares, application data
		Area of Concern	*Data availability and data integrity*
	Threat	(1) Actor *Who would exploit the area of concern or threat?*	Cyber criminal
		(2) Means *How would the actor do it? What would they do?*	Deploying malware to encrypt critical data files and database
		(3) Motive *What is the actor's reason for doing it?*	Demanding ransom, denial of service

(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Modification**	❑ **Destruction** ❑ **Interruption**	
(5) Security Requirements *How would the information asset's security requirements be breached?*	A catastrophic breach of data availability and integrity, directly impacting patient care.		
(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium**	❑ **Low**

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
	Impact Area	**Value**	**Score**
Denial of service, destroy patient trust and credibility. Ransome payment, recovery cost, potential fines.	Reputation & Customer Confidence	9	4.5
	Financial	9	4.5
Threat for clinical and admin operations. Risk for patient health and safety due to the risk of critical information go public.	Productivity	5	2.5
	Safety & Health	10	5
Fines for failure to ensure data availability under healthcare regulations.	Fines & Legal Penalties	8	4
		Relative Risk Score	**20.5**

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**

For the risks that you decide to mitigate, perform the following:

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
Servers, network center end points	Administrative Enforce the principle of least privilege; maintain a robust, tested incident response and data recovery plan. Technical Implement rigorous, isolated, and frequent data backups; application whitelisting; network segmentation. Physical

	Secure physical access to servers and backup media. What residual risk would still be accepted by the organization? The risk of a novel, zero-day ransomware variant causing limited disruption before being contained.

Allegro worksheet for SQL Injection attack

Allegro - Worksheet 10	INFORMATION ASSET RISK WORKSHEET		
Information Asset Risk – Threat	Information Asset	Web applications, database servers	
	Area of Concern	*Data confidentiality and integrity*	
	(1) Actor *Who would exploit the area of concern or threat?*	Cyber criminal	
	(2) Means *How would the actor do it? What would they do?*	Injecting malicious SQL code into input fields of the web application.	
	(3) Motive *What is the actor's reason for doing it?*	To get highly critical information, manipulation or destruction of database records	
	(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**	
	(5) Security Requirements *How would the information asset's security requirements be breached?*	Through web application.	
	(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium** ❑ **Low**

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
	Impact Area	**Value**	**Score**
Public disclosure of a mass data breach severely damages reputation. Heavy regulatory fines, compensation costs.	Reputation & Customer Confidence	7	3.5
	Financial	8	4
Effort required for forensic investigation, database	Productivity	5	2.5

	and application repair. Manipulated records could put patient's lives at	Safety & Health	9	4.5
	Penalties for failing to protect patient data.	Fines & Legal Penalties	8	4
			Relative Risk Score	**18.5**

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**
For the risks that you decide to mitigate, perform the following:			
On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*		
Web application backend, database servers	Administrative Secure coding standards and training for developers; regular penetration testing. Technical Use of parameterized queries and stored procedures; deploy a Web Application Firewall (WAF). Physical N/A (primarily a technical control). What residual risk would still be accepted by the organization? The risk associated with unknown vulnerabilities in legacy application code that cannot be immediately patched.		

Allegro worksheet for DDoS attack

Allegro - Worksheet 10		**INFORMATION ASSET RISK WORKSHEET**	
Information Asset Risk	**Threat**	Information Asset	Cloud infrastructure, web servers, patient portals
		Area of Concern	*Service availability*
		(1) Actor *Who would exploit the area of concern or threat?*	Cyber criminal

(2) Means *How would the actor do it? What would they do?*	Flooding the target's servers (MediCloud) and network infrastructure with a massive volume of malicious traffic.
(3) Motive *What is the actor's reason for doing it?*	Disruption of service
(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**
(5) Security Requirements *How would the information asset's security requirements be breached?*	A direct breach of service
(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High** ❑ **Medium** ❑ **Low**

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
	Impact Area	**Value**	**Score**
Patients are unable to access services. Cost for repairing the damage, potential loss of business	Reputation & Customer Confidence	7	3.5
	Financial	7	3.5
Clinical and admin workflows are halted. Patients with emergencies can be at risks.	Productivity	9	4.5
	Safety & Health	10	5
Legal fines.	Fines & Legal Penalties	8	4
		Relative Risk Score	**20.5**

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**
For the risks that you decide to mitigate, perform the following:			
On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*		

Network, cloud services	Administrative Develop a DDoS response plan; ensure cloud service SLAs include DDoS protection. Technical Subscribe to a cloud-based DDoS mitigation service (e.g., AWS Shield, Cloudflare); configure network redundancy. Physical N/A (handled by cloud provider). What residual risk would still be accepted by the organization? The risk of a highly sophisticated, multi-vector DDoS attack causing a short service disruption before mitigation services fully activate.

Allegro worksheet for Man-in-the-Middle attack

Allegro - Worksheet 10			**INFORMATION ASSET RISK WORKSHEET**		
Information Asset Risk		Information Asset	IoT medical devices		
		Area of Concern	*Data integrity and patient safety*		
	Threat	(1) Actor *Who would exploit the area of concern or threat?*	Cyber criminal		
		(2) Means *How would the actor do it? What would they do?*	Intercepting or altering communication between an IoT device and the cloud server.		
		(3) Motive *What is the actor's reason for doing it?*	Data theft, sabotage		
		(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Modification**	❑ **Destruction** ❑ **Interruption**	
		(5) Security Requirements *How would the information asset's security requirements be breached?*	A breach or vulnerability in a IoT device		
		(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium**	❑ **Low**
	(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*		(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		

		Impact Area	Value	Score
	Patients losing trust in hospital devices. Costs to repair vulnerabilities, potential lawsuits, security patches.	Reputation & Customer Confidence	8	4
		Financial	8	4
	Patients could be in great danger.	Productivity	-	-
		Safety & Health	9	4.5
	Regulatory fines for insecure medical devices	Fines & Legal Penalties	7	3.5
			Relative Risk Score	**16**

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**
For the risks that you decide to mitigate, perform the following:			
On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*		
Network, IoT devices	Administrative Security policy for IoT device procurement (requiring strong encryption). Technical Implement strong encryption (TLS) for all data in transit; use network segmentation to isolate IoT devices on a separate VLAN. Physical Ensure physical security of devices to prevent tampering. What residual risk would still be accepted by the organization? The risk associated with older, legacy IoT devices that lack the capability for modern encryption, until they can be phased out.		

Threat prioritization

To effectively prioritize the cyber threats facing MediCloud Health, a risk matrix approach is used. This involves calculating a risk score for each threat scenario by estimating its potential impact (Disruption Cost) and its Likelihood of occurrence. The resulting score allows for objective comparison and prioritization.

Risk matrix

Asset	Attack	Distribution cost (0-100)	Likelihood (0-100)	Impact (cost*likelihood)
Health record database	Ransomware/ SQL injection	95	80	7600
Workstations	Phishing	85	90	7650
Web applications	SQL injection	90	70	6300
IoT medical devices	MITM attack	80	60	4800
Cloud servers	DDoS attack	70	65	4550
Payment processing systems	Payment fraud	65	50	3250
Admin accounts	Insider threats	75	40	3000
Staff/ doctors	Insider threats	60	60	3600

Based on the calculated risk scores, the threats are prioritized as follows:

Phishing & Ransomware (Highest Priority)

These two threats are linked and represent the most critical risk. Phishing is the most common initial attack vector, with an extremely high likelihood (90) as it targets the human element, which is often the weakest link. Its high impact (85) stems from its role as a gateway for more devastating attacks.
Ransomware directly targeting the EHR database has the single highest potential impact (95). An encrypted EHR system halts clinical operations entirely, creating a direct and immediate threat to patient safety. It also causes massive financial loss (ransom, recovery costs, fines) and irreparable reputational damage. The high likelihood (80) is due to the healthcare sector being a prime target for ransomware gangs because of the critical need for data availability. The combination of the highest impact and high likelihood makes this the top-priority threat scenario.

SQL Injection (High Priority)

This threat scores highly due to its severe impact on data confidentiality and integrity. A successful SQL Injection attack on the EHR or web applications can lead to a massive data breach, resulting in high impact scores (90, 95). The likelihood (80) remains significant because web applications are constantly probed for such vulnerabilities by automated tools and attackers. The compromise of sensitive patient data carries severe regulatory consequences under laws like HIPAA and GDPR, justifying its high-priority status.

Reflection

This risk analysis provides a crucial strategic blueprint, clearly demonstrating that threats like phishing and ransomware must be the top priority due to their high likelihood and severe impact on patient safety and data integrity. It teaches us that the human element is the greatest vulnerability and that in healthcare, impact on data confidentiality and availability outweighs all other factors. This prioritization will directly guide the subsequent design of the security lab, the selection of defensive tools, and the focus of the mitigation and incident response plans, ensuring resources are allocated to address the most significant risks first.

LAB ARCHITECTURE

Lab design principles

The Cyber Security Lab is founded on two essential principles to guarantee its safety and effectiveness.
Isolation is paramount to prevent any risk to live patient systems. The lab will be hosted on a physically separate server with strict firewall rules, creating a completely air-gapped environment. This ensures that all security testing, including attack simulations, is contained within the lab without any possibility of impacting MediCloud's operational network.
Realism and Scalability ensure the lab provides accurate and lasting value. The architecture will be a precise virtual replica of MediCloud's production environment, including EHR systems, web applications, and IoT devices. Using virtual machines allows the lab to be easily expanded, ensuring it can evolve alongside MediCloud's future growth and technological changes.

Lab architecture

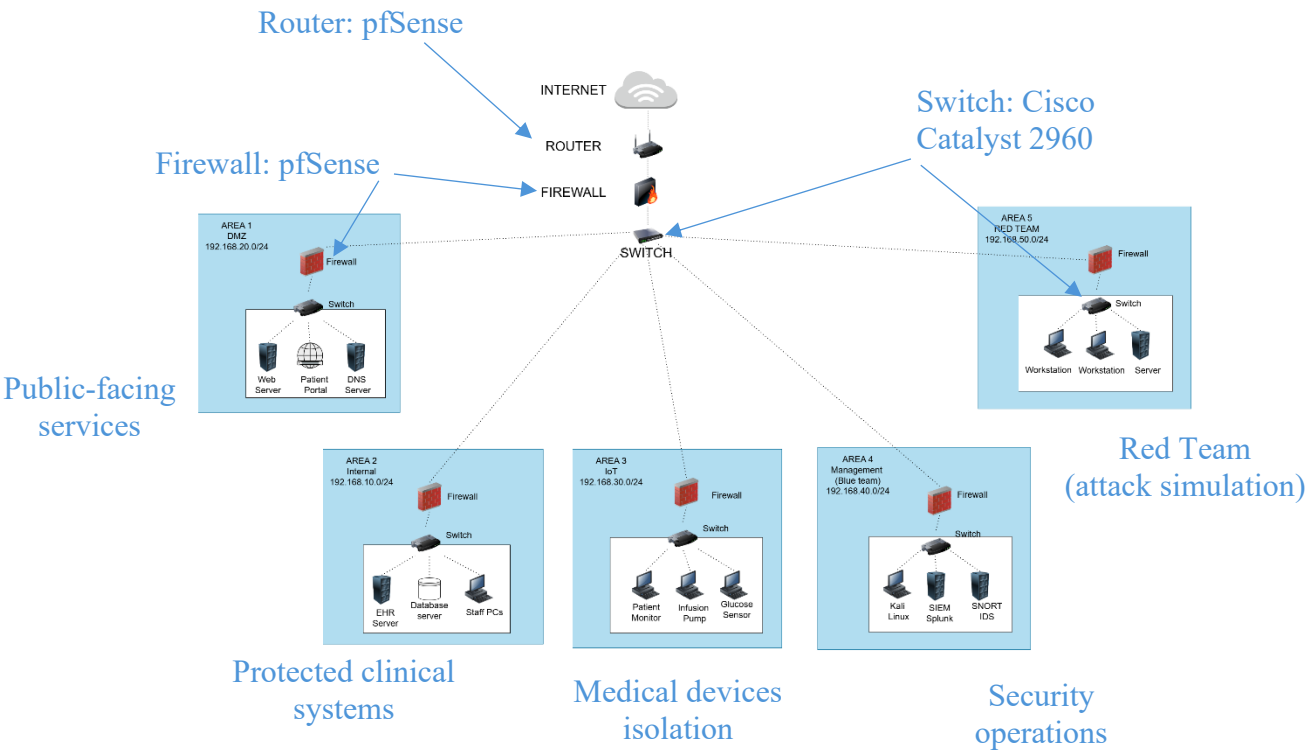


Figure 1. Lab architecture

Virtual machines

i. EHR Server

This server hosts all patient medical records using Windows Server 2019, the healthcare industry standard. It ensures compatibility with clinical software like Epic and provides robust security features including Active Directory integration for access control.

ii. Web Server

Hosting the patient portal, Ubuntu Linux provides a secure, high-performance platform for web traffic. Its open-source nature offers cost-effective stability and strong defenses against web-based attacks.

iii. Database Server

Running MySQL, this dedicated server stores structured patient data separately from application logic. This separation enhances security, performance, and simplifies data management and recovery processes.

iv. Staff Workstations

Windows 10/11 workstations simulate real staff computers for testing phishing and malware attacks. They enable realistic evaluation of endpoint security controls and staff training.

v. Kali Linux

This penetration testing platform contains tools like Metasploit and Nmap for ethical attack simulation. It proactively identifies vulnerabilities without risking the production environment.

vi. Workstations (Red team)

These are the primary machines where Red Team operators sit. They run Kali Linux and all the attacking tools (Metasploit, Burp Suite, etc.). Having multiple allows different operators to work on different attacks simultaneously.

vii. Server (Red team)

This is for advanced, realistic simulations. It acts as a central server "call home" point for malware the Red Team deploys inside the network. It makes the simulation much more realistic but is not strictly mandatory for a basic lab.

viii. Firewalls (pfSense)

These enterprise-grade firewalls provide stateful inspection and intrusion prevention between network segments. They enforce segmentation to contain breaches and control inter-zone traffic (Sundholm, 2019).

ix. Core Switch (Cisco Catalyst 2960)

This Layer 3 switch is selected to serve as the network backbone, providing high-speed routing between all VLANs. Its ability to handle inter-VLAN routing at wire speed ensures efficient traffic flow while maintaining logical separation between critical segments like the clinical LAN and the DMZ (Lammle, 2003).

x. Access Switches (Cisco Catalyst 2960)

These switches connect all devices within their respective network segments (DMZ, Internal, IoT). Using the same model ensures consistent management and reliable performance, while their VLAN support enforces the network segmentation that is fundamental to the lab's security architecture (Lammle, 2003).

xi. Router (pfSense)

The pfSense software is deployed as the network router due to its robust feature set and cost-effectiveness. It performs critical routing functions between the lab and the simulated internet, and its integrated firewall capabilities provide an essential first line of defense at the network perimeter (Hadi et al., 2024).

Network segmentation

The lab environment implements a network segmentation through the use of Virtual Local Area Networks (VLANs) to logically separate system components based on their function and sensitivity. This design establishes four distinct segments: VLAN 20 (DMZ) for public-facing

services, VLAN 10 (Internal) for protected clinical systems, VLAN 30 (IoT) for medical device isolation, and VLAN 40 (Management) for security operations. Each segment is assigned a unique IP subnet, which enforces isolation and contains potential security breaches by preventing lateral movement across different parts of the network.

This multi-layered, segmented architecture is designed to provide defense-in-depth, a critical security principle for protecting sensitive healthcare data. The strategic placement of firewalls between each VLAN creates distinct security zones, ensuring that a breach in one segment, such as the public-facing DMZ, does not compromise critical clinical systems in the Internal LAN. This design effectively contains threats and prevents lateral movement by attackers across the network. Furthermore, the centralized core switch enables efficient traffic management and granular security monitoring for all segments, creating a scalable and resilient security posture tailored to MediCloud's operational needs (Ahad et al., 2019).

Security controls

A multi-layered security control framework is deployed to protect the segmented network. This includes a perimeter firewall at the internet boundary and internal firewalls between each VLAN segment to filter traffic and enforce access policies. A Snort Intrusion Detection System (IDS) is positioned to monitor all network traffic from the management LAN, providing real-time threat detection. These technical controls are supplemented by restrictive firewall rules that govern communication between segments, ensuring that only authorized traffic flows according to the principle of least privilege. This defense-in-depth strategy directly secures against threats like ransomware propagation from workstations to servers, unauthorized access to the EHR database from the DMZ, and malicious manipulation of vulnerable IoT devices.

Red team (Attack simulator)

Justification

The Red Team area provides controlled offensive security testing to proactively identify vulnerabilities. Its purpose is to simulate real-world attacker methodologies by targeting all network segments from an isolated VLAN. This works by allowing ethical hackers to launch attacks from dedicated workstations, testing the effectiveness of security controls and the Blue Team's detection capabilities. The key advantage is the discovery of security weaknesses before malicious actors can exploit them, significantly enhancing MediCloud's overall cyber resilience.

Red Team Attacking Tools

Nmap: To scan the network and discover all live hosts, open ports, and running services on target systems.

Nessus: To automatically find known vulnerabilities (like unpatched software) in the EHR server or web applications that can be exploited.

Metasploit Framework: The core tool for launching exploits against known vulnerabilities to gain an initial foothold on a system, such as the EHR Server.

Burp Suite: To find and exploit web application flaws (like SQL Injection) in the Patient Portal, potentially stealing patient data.

Mimikatz: To steal passwords and Windows credentials from the memory of a compromised Staff PC, allowing the Red Team to move laterally to more important systems.

Hydra: To perform brute-force attacks on login services (like SSH or the Patient Portal) to guess weak passwords and gain access.

Cobalt Strike: It allows the Red Team to remotely control compromised machines, steal data, and move stealthily through the network, providing the most realistic simulation of an advanced hacker.

Tools justification

Vulnerability Assessment

Nmap is utilized for network discovery and port scanning, providing a clear map of the attack surface by identifying all active devices and services running on the network. This is a critical first step in understanding what systems are accessible (Lyon, 2008).

Nessus/OpenVAS are comprehensive vulnerability scanners that proactively identify known security weaknesses, misconfigurations, and unpatched software across the entire lab environment. Their extensive and regularly updated plugin databases are essential for maintaining a strong security posture against evolving threats (Anand et al., 2020).

We run these from our Kali Linux machine in the Management LAN (192.168.40.10). We are capable of scanning all other networks (DMZ, Internal, IoT) to discover devices and find vulnerabilities without being in the same segment.

Penetration Testing

Metasploit serves as the core exploitation framework, allowing security teams to safely simulate real-world attack scenarios to validate the severity of identified vulnerabilities. This helps in understanding the potential impact of a breach on clinical systems (*Metasploit: The Penetration Tester's Guide - David Kennedy, Jim O'Gorman, Devon Kearns, Mati Aharoni - Google Books*, n.d.).

Burp Suite is the industry-standard tool for web application security testing. It is critical for identifying and exploiting vulnerabilities like SQL Injection and Cross-Site Scripting (XSS) in MediCloud's patient portal and other web services (Stuttard & Pinto, 2011).

Hydra is employed to test the strength of authentication mechanisms by performing brute-force and dictionary attacks against network services. This helps ensure that weak passwords cannot be easily compromised to gain unauthorized access (Stuttard & Pinto, 2011).

We also run these from the Kali Linux machine. We use them to launch attacks against targets in other segments, such as trying to exploit the EHR Server (Internal) or brute-forcing the Patient Portal (DMZ).
And burp suite, we use it to configure our web browser to route traffic through it. This lets us intercept and manipulate HTTP requests sent to the Web Server and Patient Portal in the DMZ (192.168.20.x) to test for SQL Injection.

Network Monitoring

Wireshark provides deep packet inspection for granular network traffic analysis. It is indispensable for forensic investigations, troubleshooting, and understanding the nature of malicious communications during an attack simulation.

Snort functions as the primary Intrusion Detection and Prevention System (IDS/IPS), monitoring all network segments in real-time for suspicious patterns and known attack signatures. It provides the first line of automated defence by alerting on or blocking malicious activity.

We installed SNORT IDS on the Monitoring Server in the Management LAN (192.168.40.30). Configure it to monitor traffic from all other VLANs (DMZ, Internal, IoT) by setting up a mirror port on our core switch to send it a copy of all network traffic.

While we use Wireshark on Kali Linux machine or the Monitoring Server. We use it to capture and inspect packets on the Management LAN, or use it to analyze packet captures from Snort.

Incident Response

Splunk is implemented as the Security Information and Event Management (SIEM) solution. We installed SIEM Server in the Management LAN (192.168.40.20). To configure all other servers, workstations, and network devices (firewalls, switches) to send their log files to this central Splunk server.
It aggregates and correlates logs from all systems, applications, and security tools, providing a centralized dashboard for rapid threat detection, investigation, and incident response, which is crucial for compliance and minimizing damage from a security breach.

ATTACK SIMULATIONS

Man In The Middle attack (MITM)

Attack methodology

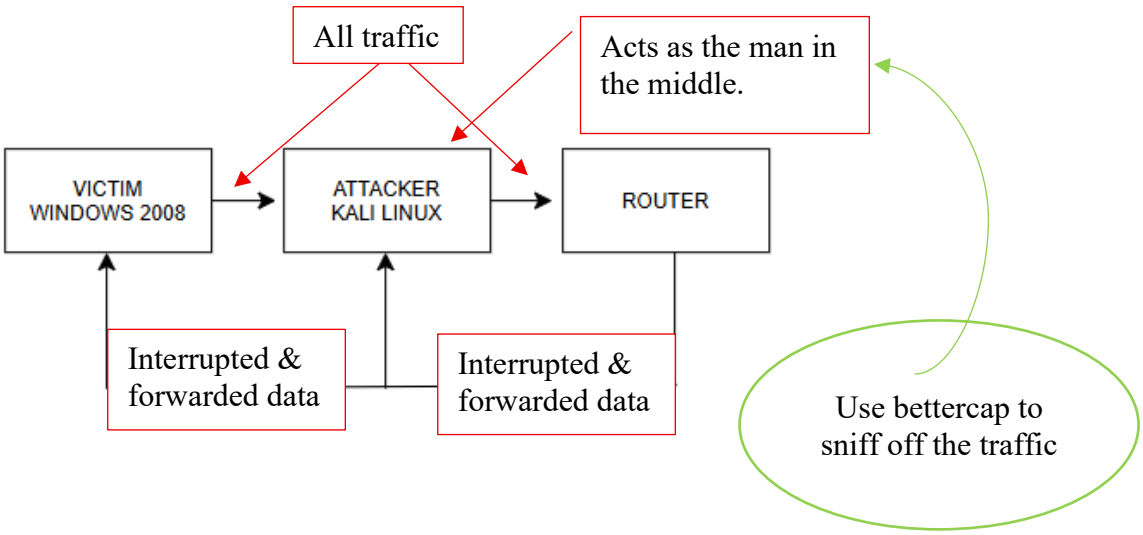


Figure 2. MITM flow

The attack methodology describes a Man-in-the-Middle (MITM) attack using ARP poisoning with Bettercap. The attack targets the local network, specifically focusing on a Windows Server 2008 machine initially, and later switching to a personal device with IP address 192.168.1.4.
The key steps in the process are:

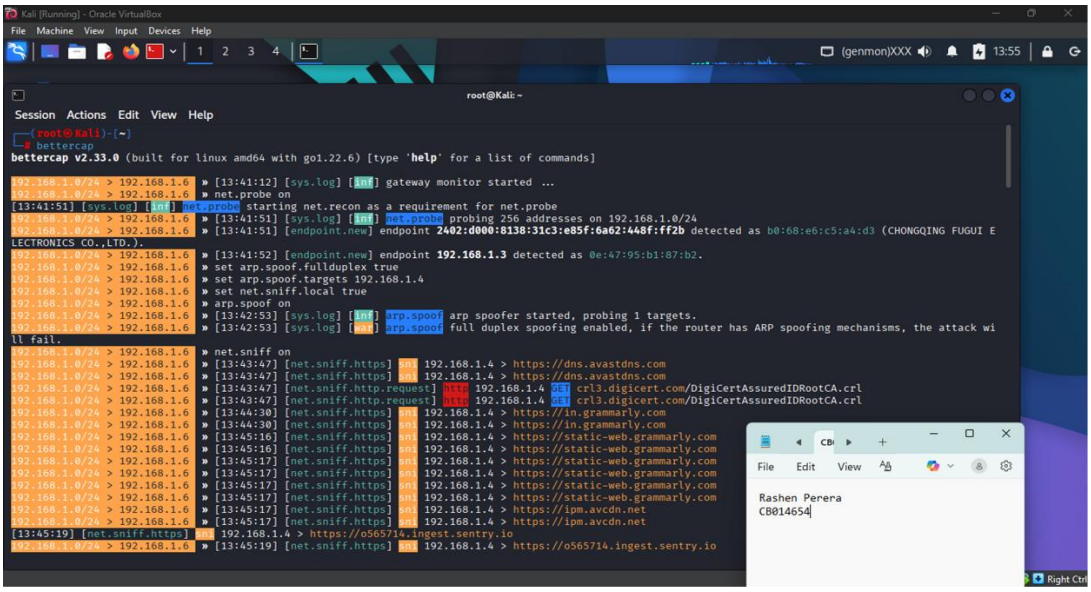
i. Network Reconnaissance: The attacker identifies the target device (192.168.1.4) and the gateway within the local network.
ii. ARP Cache Poisoning: The attacker sends forged ARP replies, associating their MAC address with the legitimate IP addresses of the target and gateway, tricking the network into routing traffic through the attacker's machine.
iii. Traffic Interception: The attacker enables IP forwarding to relay traffic between the target and the gateway while maintaining a connection. This allows them to observe and capture data without disrupting the flow of traffic.
iv. Data Extraction: The attacker captures and analyses the network traffic, extracting potentially sensitive information such as website access logs and connected devices.

Commands Used:

- net.probe on: Activates network probing to detect devices on the local network.
- set arp.spoof.fullduplex true: Enables full-duplex ARP spoofing, allowing the attacker to send ARP replies to both the victim and the gateway simultaneously.
- set arp.spoof.targets 192.168.1.4: Specifies the target device (192.168.1.4) for ARP poisoning.

- set net.sniff.local true: Enables local network sniffing to capture and analyze traffic.
- arp.spoof on: Activates ARP spoofing, launching the attack.
- net.sniff on: Starts sniffing network traffic to capture data.

The process demonstrated the potential of Bettercap for intercepting and analysing communication on a local network, allowing the attacker to identify websites accessed and monitor connected devices. This attack showcases the vulnerability of local networks to MITM attacks and the importance of network security measures to prevent such exploits.



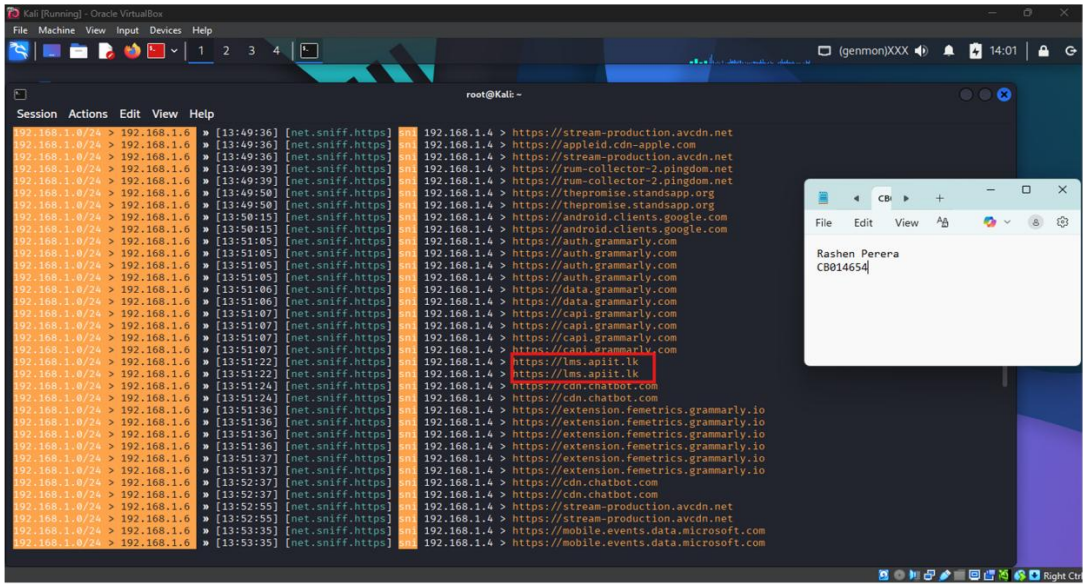


Figure 3. MITM 1

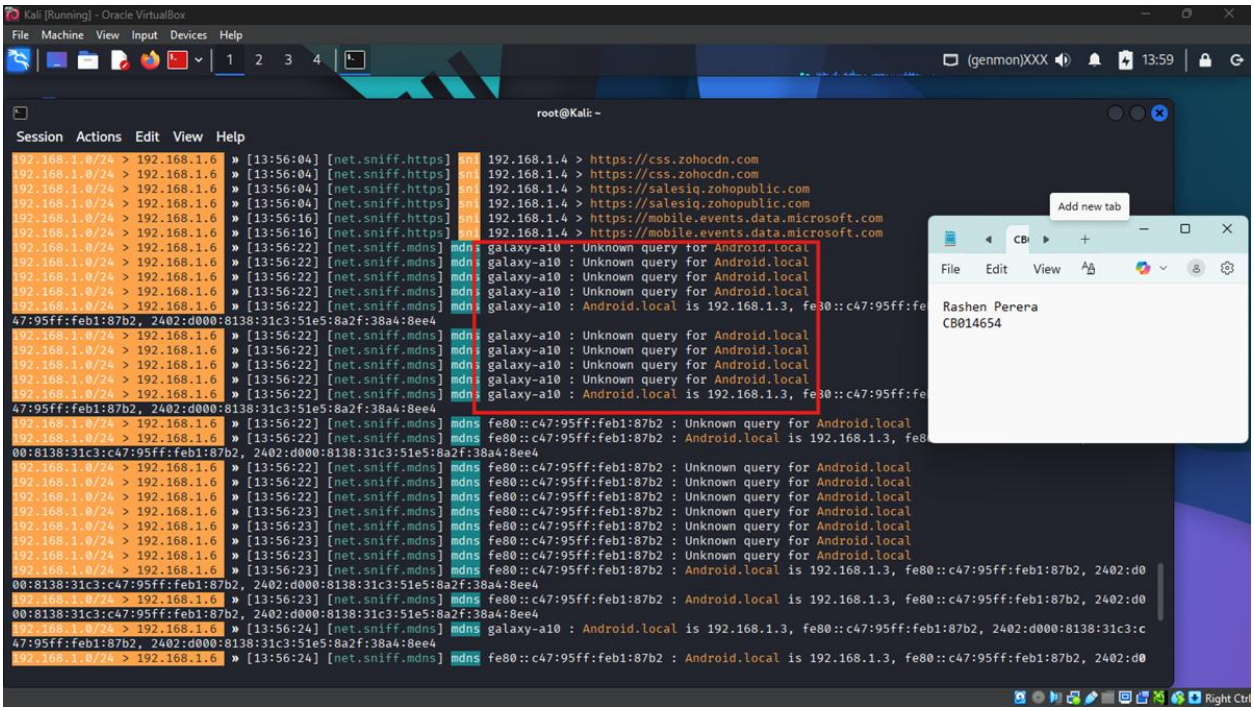


Figure 4. MITM 2

Defensive Strategies

Based on the MITM simulation, the following security controls should be implemented:

1. Encryption-in-Transit:

- Enforce TLS 1.3+ for all network communications
- Implement certificate pinning for critical services
- Use HTTPS for all web applications

2. Network Segmentation:

- Implement VLAN segregation for IoT devices
- Use port security to prevent unauthorized connections
- Deploy network access control (NAC

3. Certificate Management:

- Implement proper certificate authority infrastructure
- Monitor for rogue certificates
- Use mutual TLS authentication for critical systems

4. Network Monitoring:

- Deploy intrusion detection systems on all segments
- Monitor for ARP spoofing and DNS poisoning attempts

- Implement traffic analysis for anomaly detection

Distributed Denial of Service DDoS attack

Attack methodology

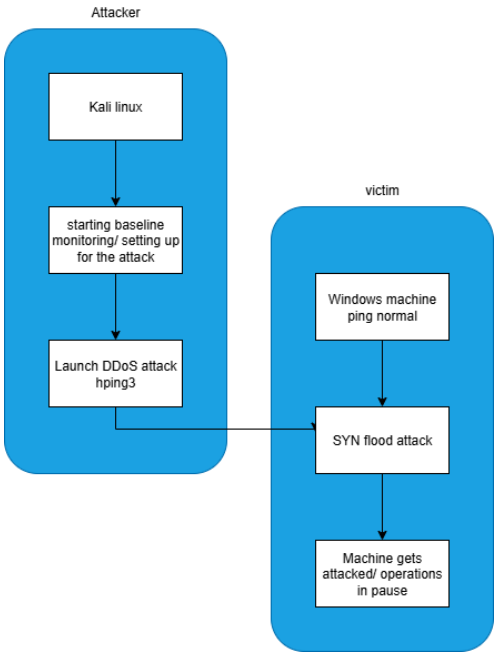


Figure 5. DDoS flow

This report analyzes a Distributed Denial of Service (DDoS) attack, specifically a SYN Flood attack, executed on a Windows Server 2008 machine using Kali Linux and the hping3 tool. The attack focuses on flooding the target server with SYN packets, causing resource exhaustion and service disruption.

The goal was to overwhelm the server with a large volume of SYN packets to cause resource depletion and disrupt the server's availability by exploiting the TCP handshake process.

A SYN Flood attack was carried out using the hping3 tool on Kali Linux, targeting the Windows Server 2008 machine with IP 192.168.56.105, specifically flooding port 80 (HTTP service). The attack manipulated the TCP handshake by sending SYN packets without completing the handshake, leading to resource exhaustion.
Attack Steps:

- Preparation: The attack begins with the following command:
- sudo hping3 -S --flood -p 80 192.168.56.105, This sends a high volume of SYN packets to port 80 of the target.
- Execution: The attacker floods the target with SYN packets, consuming server resources as the target tries to allocate resources for each packet without completing the TCP

handshake.

- Verification: A ping test was run to check if the target server remained responsive, confirming that the server was overwhelmed but still receiving requests.

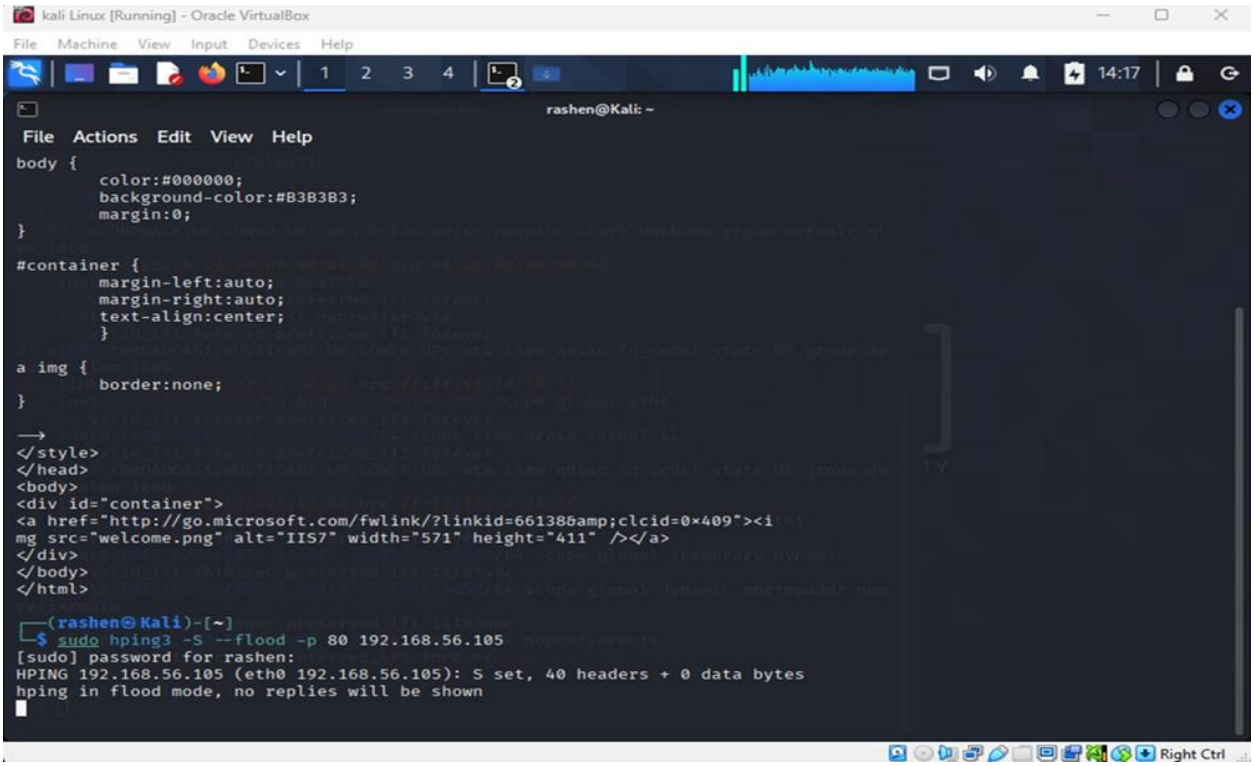


Figure 6. DDoS 1

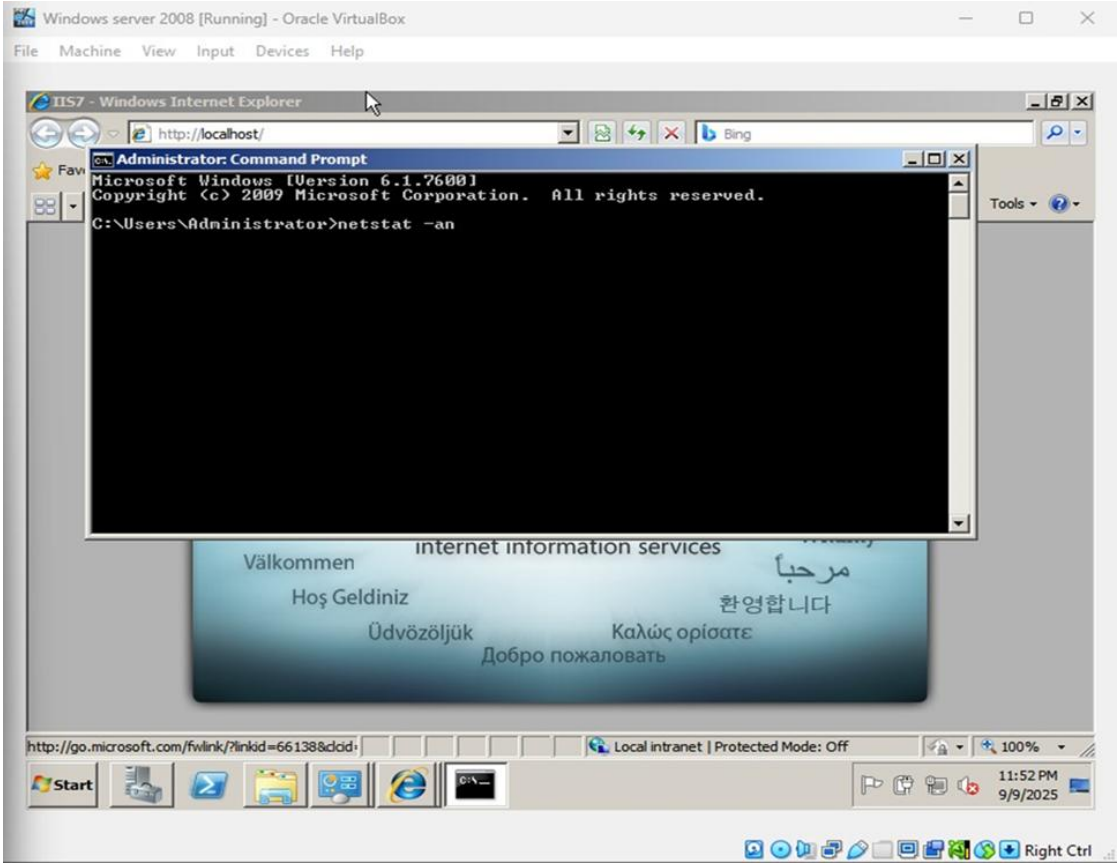


Figure 7. DDoS 2

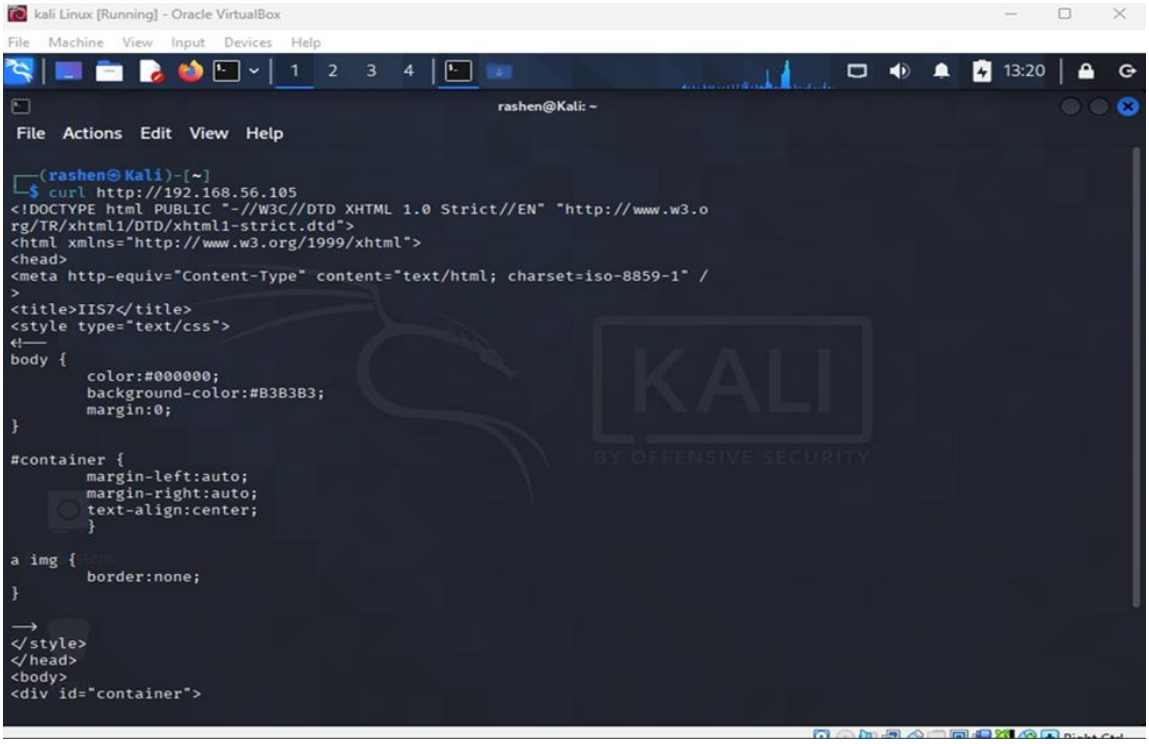


Figure 8. DDoS 3

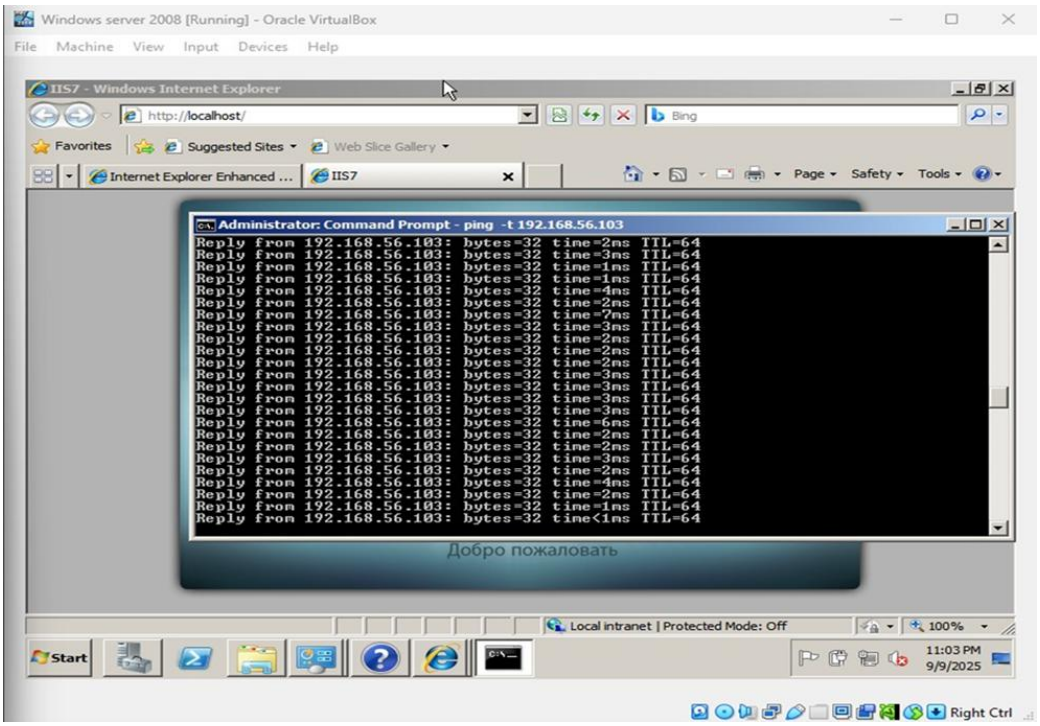


Figure 9. DDoS 4

Defensive Strategies

Based on the DDoS simulation, the following security controls should be implemented:

1. DDoS Protection Service:

- Subscribe to cloud-based DDoS mitigation services
- Implement traffic scrubbing capabilities
- Use anycast network distribution

2. Network Infrastructure:

- Deploy next-generation firewalls with DDoS protection
- Implement rate limiting and traffic shaping
- Configure SYN cookie protection

3. Redundancy and Scaling:

- Implement load balancing across multiple servers
- Use auto-scaling for cloud infrastructure
- Maintain redundant internet connections

4. Incident Response Planning:

- Develop DDoS-specific response procedures

- Establish communication protocols with ISPs
- Conduct regular DDoS response drills

Phishing attack

Attack methodology

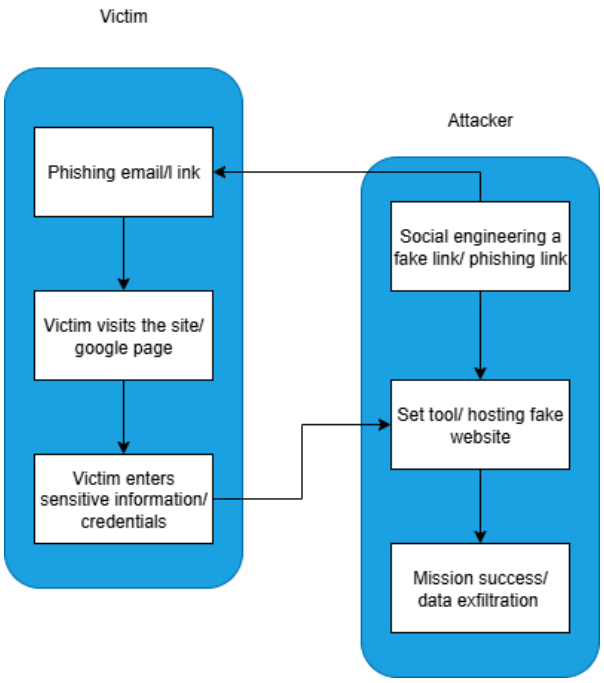


Figure 10. Phishing flow

Phishing attacks involve tricking a victim into divulging sensitive information, often by masquerading as a trustworthy entity. The simulation described in the provided document outlines a process of executing a phishing attack, using the Social-Engineer Toolkit (SET) on Kali Linux. Here's a breakdown of the steps involved:

1. Attack Setup: The attacker utilises the Social-Engineer Toolkit (SET) to clone a legitimate website, such as Google, to create a fake login page designed to capture login credentials. This is done on a Kali Linux machine, while the victim is simulated on a Windows machine.
2. Sending the Phishing Email: The attacker sends an email to the victim with a message designed to tempt them into clicking a link that directs them to the fake login page. For example, the email in the simulation claimed the victim had won a prize and provided a link to "claim their prize" or "log in to your account for account safety".
3. The Fake Login Page: Once the victim clicks the malicious link, they are redirected to the cloned login page, where they are prompted to enter their

credentials The page appears to be a legitimate Google login form, but it is actually a fake.

4. Credential Harvesting: After the victim enters their credentials, the attacker captures this information. The credentials are harvested through the attacker's machine, which monitors and records the submitted login data (depicted on page 6).

Summary of Commands Used:

1. git clone --depth=1 https://github.com/htr-tech/zphisher.git – Clones the zphisher repository from GitHub.
2. cd zphisher – Tries to change into the zphisher directory.
3. ./zphisher.sh – Runs the zphisher script, likely for phishing activities.

Now Zphisher is loading, and we can select Google for this task, Google email password stealing.
After we can send phishing mail to victim like this.
When victim click the link and add user email and password, they are shown in our Kali machine.

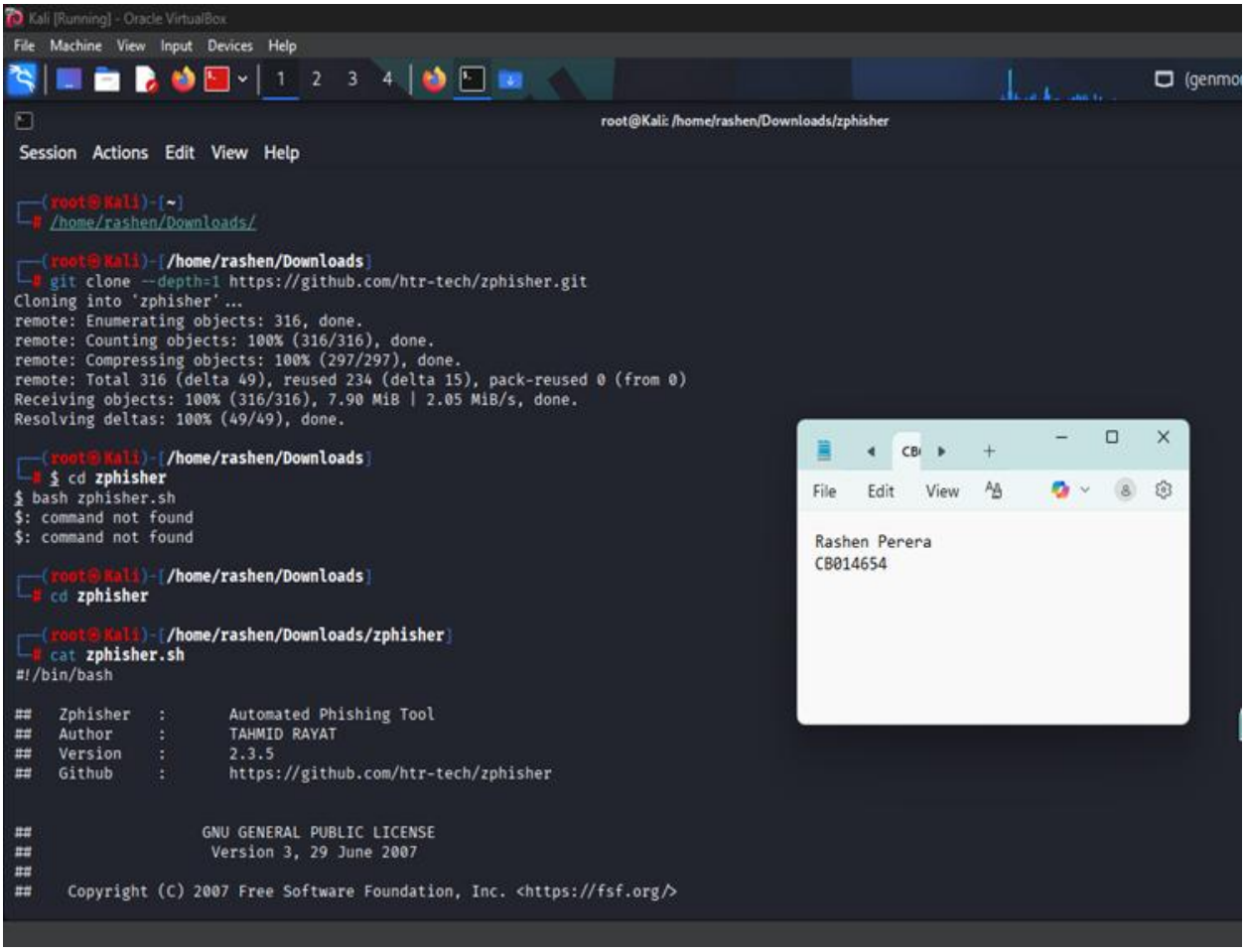


Figure 11. Phishing 1

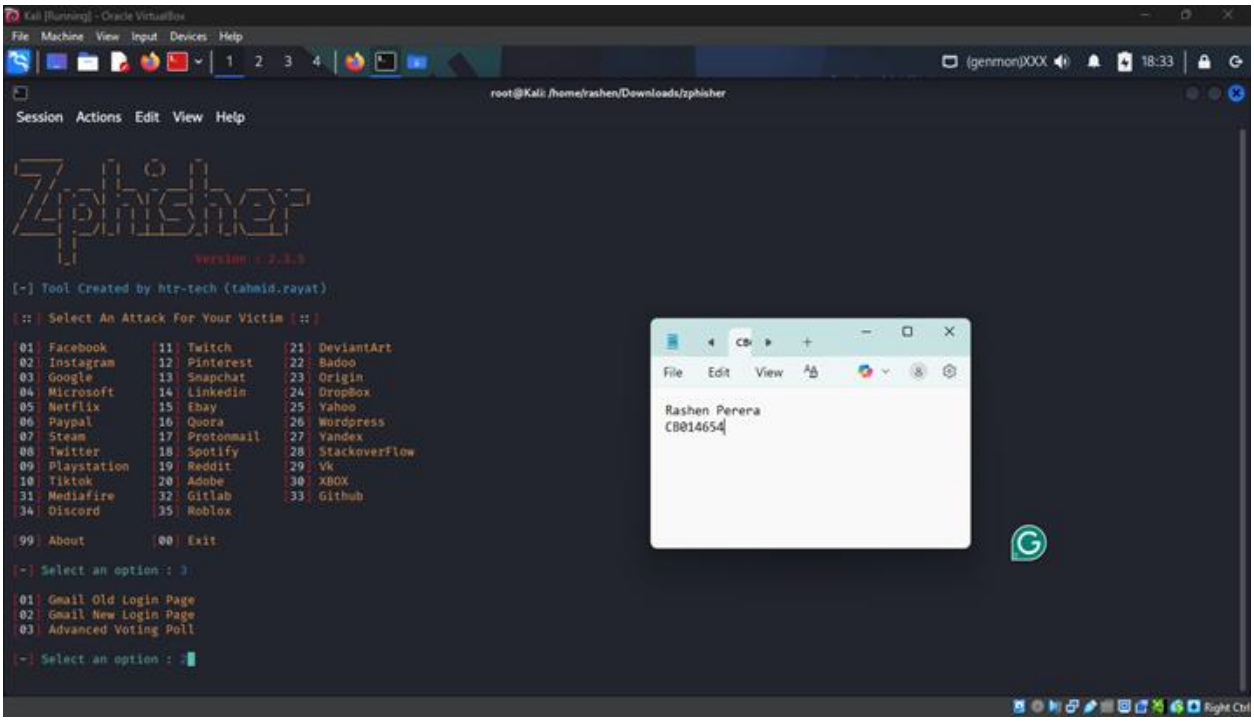


Figure 12. Phishing 2

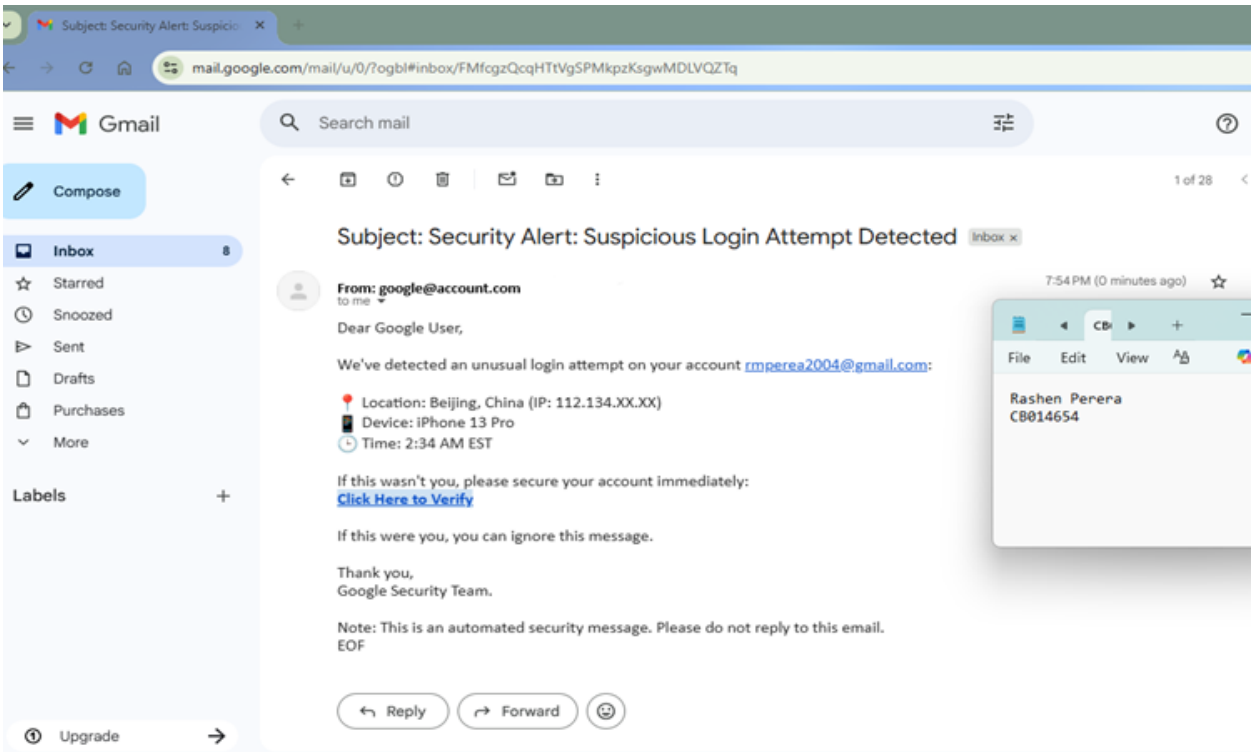


Figure 13. Phishing 3

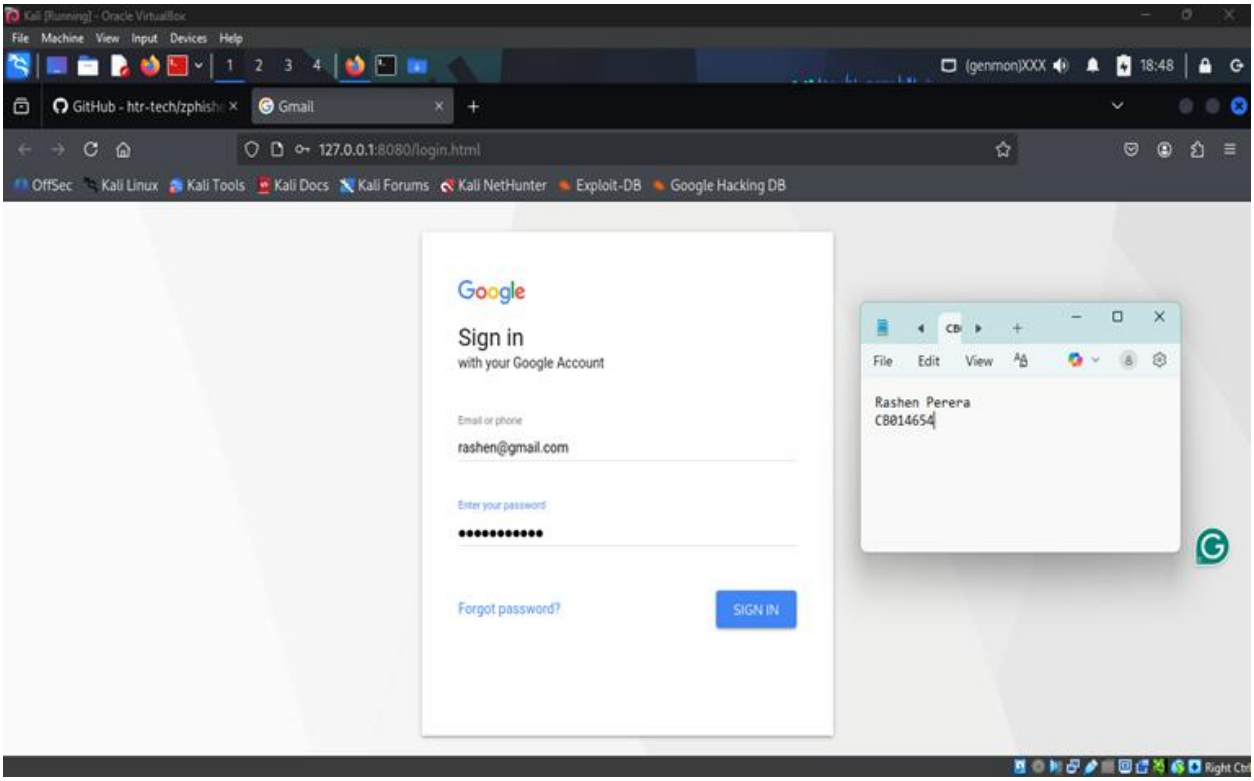


Figure 14. Phishing 4

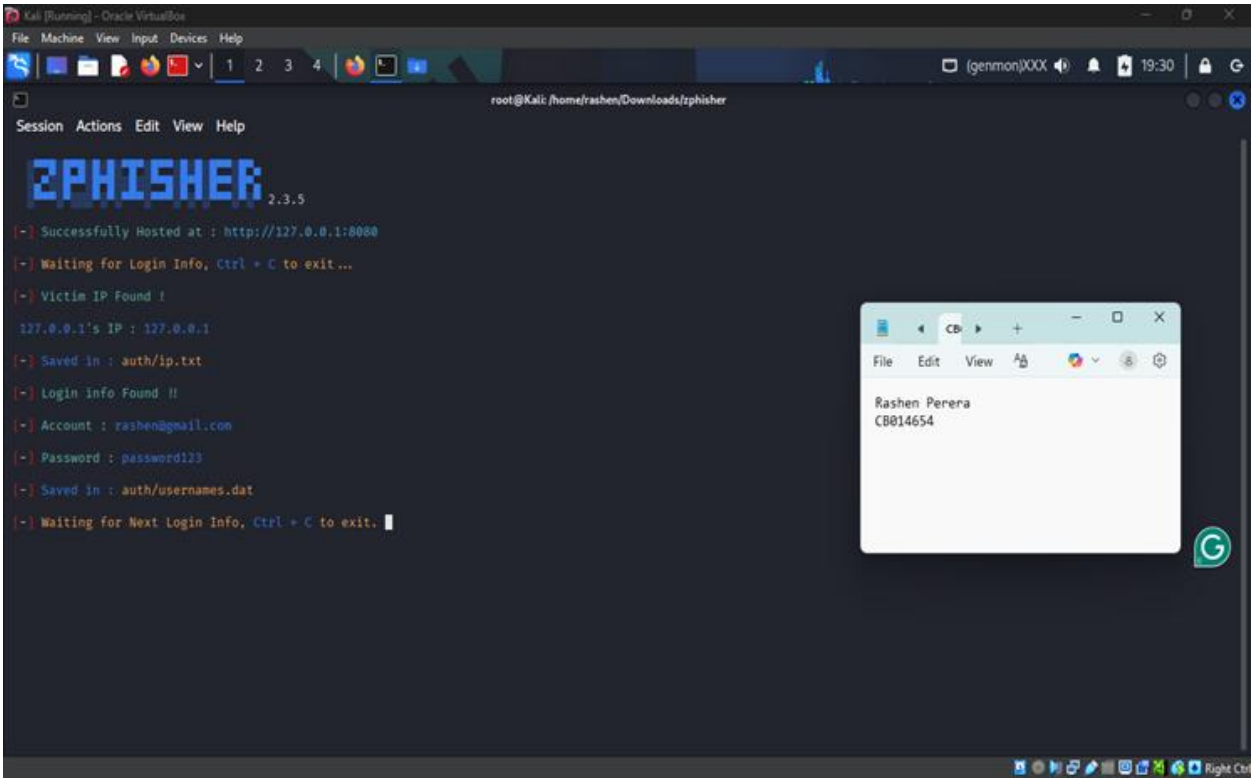


Figure 15. Phishing 5

Defensive Strategies

Based on the phishing simulation, the following security controls should be implemented:

1. Multi-Factor Authentication:

- Implement MFA for all external-facing services
- Use phishing-resistant authentication methods
- Enforce MFA for administrative accounts

2. Email Security:

- Deploy advanced email filtering solutions
- Implement DMARC, DKIM, and SPF protocols
- Use AI-based threat detection for emails

3. Security Awareness Training:

- Conduct regular phishing simulation exercises
- Train staff to identify suspicious emails
- Implement reporting mechanisms for phishing attempts

4. Access Control:

- Implement conditional access policies
- Restrict access based on device compliance
- Use risk-based authentication

SQL Injection attack

Attack methodology

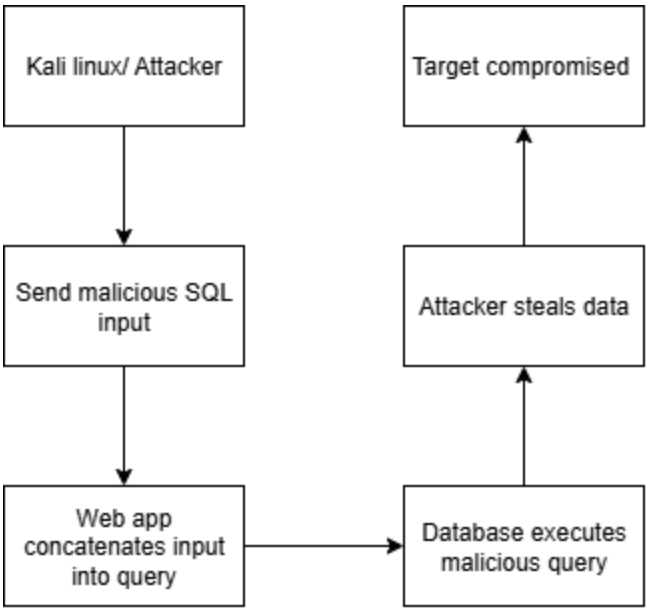


Figure 16. SQLI flow

Overview of SQL Injection Attack
SQL Injection is a common web security attack where malicious users insert harmful SQL commands into web application input fields. This attack targets the database layer of web applications and can lead to unauthorized access to sensitive data, data theft, and complete system compromise.[1][2]
In the context of MediCloud Health's customer-facing web application, SQL injection poses a significant threat to patient data security. Attackers can exploit poorly designed login forms, search boxes, or any input field that communicates with the database to extract patient records, modify medical data, or gain administrative access to the system.[3]
Lab Setup for SQL Injection Testing
Tools Used:
- Kali Linux (Attacker machine)
- DVWA (Damn Vulnerable Web Application)
- Burp Suite (Web application security testing)
- Web browser (Firefox/Chrome)
- Apache web server
- MySQL database

Network Configuration:
- Attacker machine: Kali Linux VM
- Target application: DVWA running on Apache server
- Database: MySQL backend storing user credentials

SQL Injection Attack Simulation Steps:
Clone DVWA from GitHub and Start Apache server and MySQL on kali
Commands executed:

```
┌──(maleesha㉿Maleesha)-[~]
└─$ sudo git clone https://github.com/digininja/DVWA.git
Cloning into 'DVWA'...
remote: Enumerating objects: 5588, done.
remote: Counting objects: 100% (59/59), done.
remote: Compressing objects: 100% (27/27), done.
remote: Total 5588 (delta 47), reused 32 (delta 32), pack-reused 5529 (from 3)
Receiving objects: 100% (5588/5588), 2.65 MiB | 1.17 MiB/s, done.
Resolving deltas: 100% (2772/2772), done.
```

Figure 17. SQLI 1

```
┌──(maleesha㉿Maleesha)-[~]
└─$ sudo service apache2 start

┌──(maleesha㉿Maleesha)-[~]
└─$ sudo service mysql start
```

Figure 18. SQLI 2

I cloned the DVWA repository from GitHub into my home directory and then started the necessary web and database services on Kali Linux. First, I ran "sudo git clone https://github.com/digininja/DVWA.git" to download all DVWA files.
Next, I started Apache and MySQL using "sudo service apache2 start" and "sudo service mysql start".
This ensured the DVWA application files were in place under /var/www/html/dvwa and that the Apache web server and MariaDB database were running, making DVWA accessible in the browser for testing.

Access DVWA Interface
URL accessed: http://localhost/dvwa/setup.php

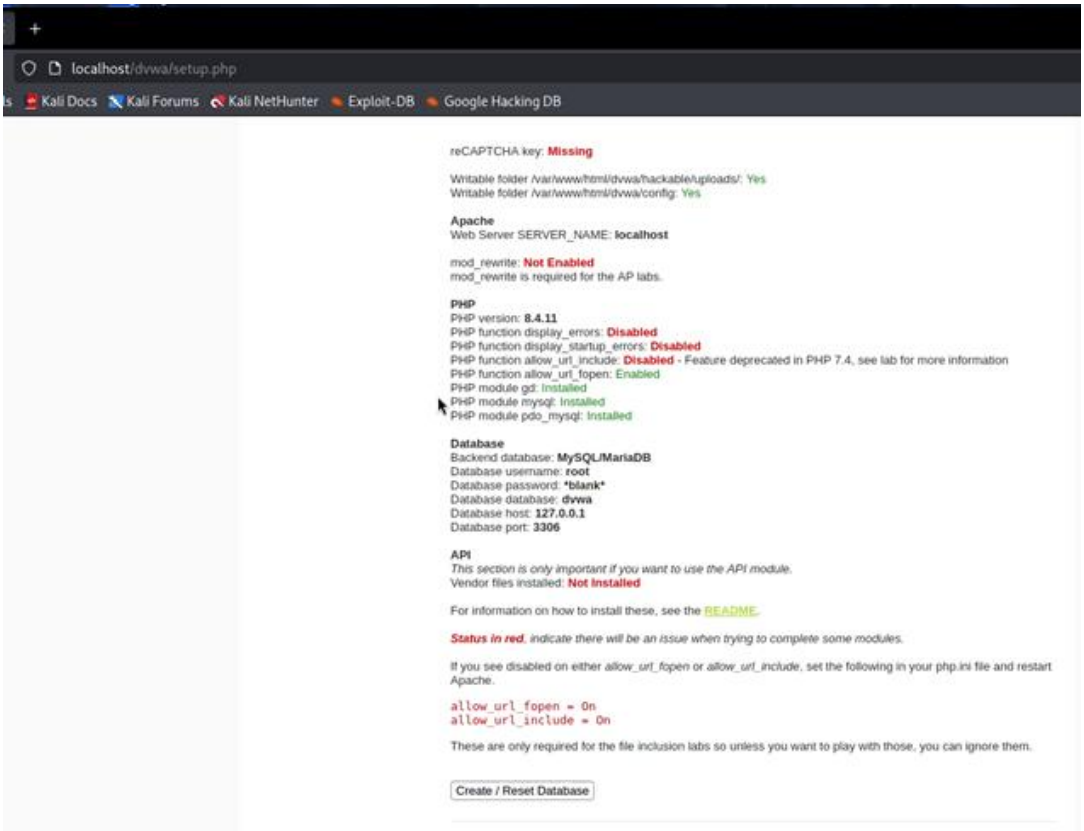


Figure 19. SQLI 3

open your browser and go to “http://localhost/dvwa/setup.php”.

Login

- Username: admin
- Password: password

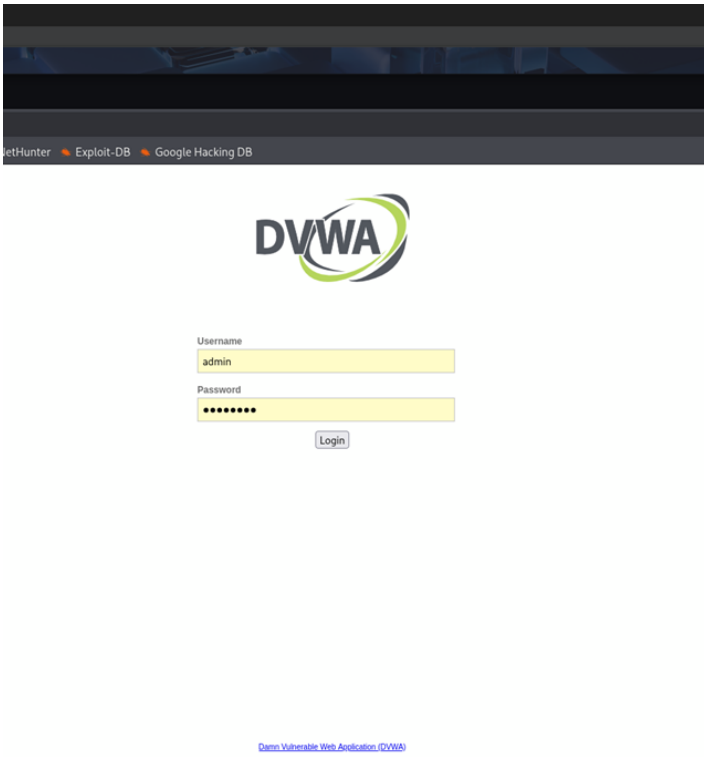


Figure 20. SQLI 4

Perform SQL injection
input: 1'

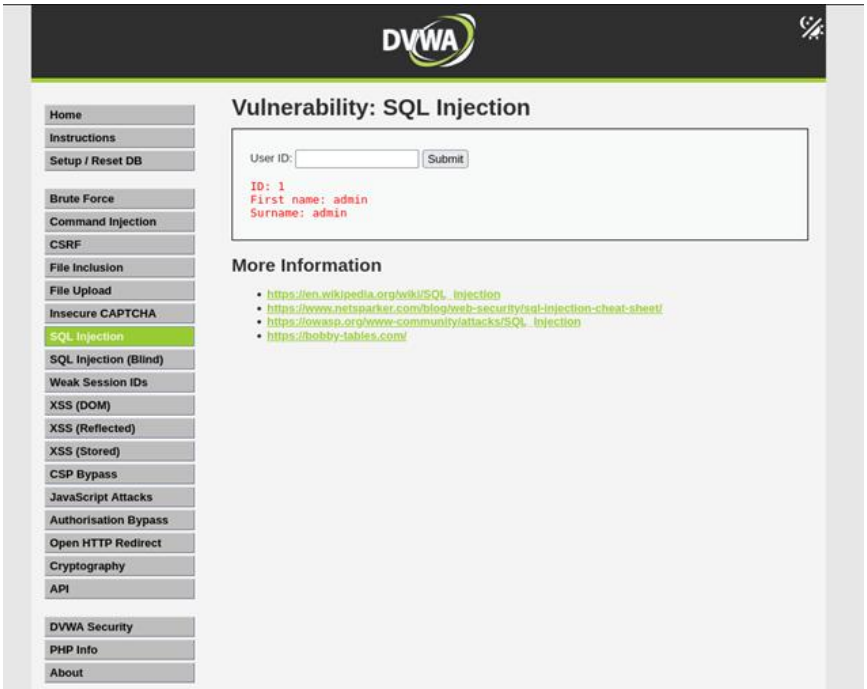


Figure 21. SQLI 5

Purpose: Check if single quote causes database error

Expected result: SQL error message

Boolean-Based SQL Injection

Input: 1' OR '1'='1

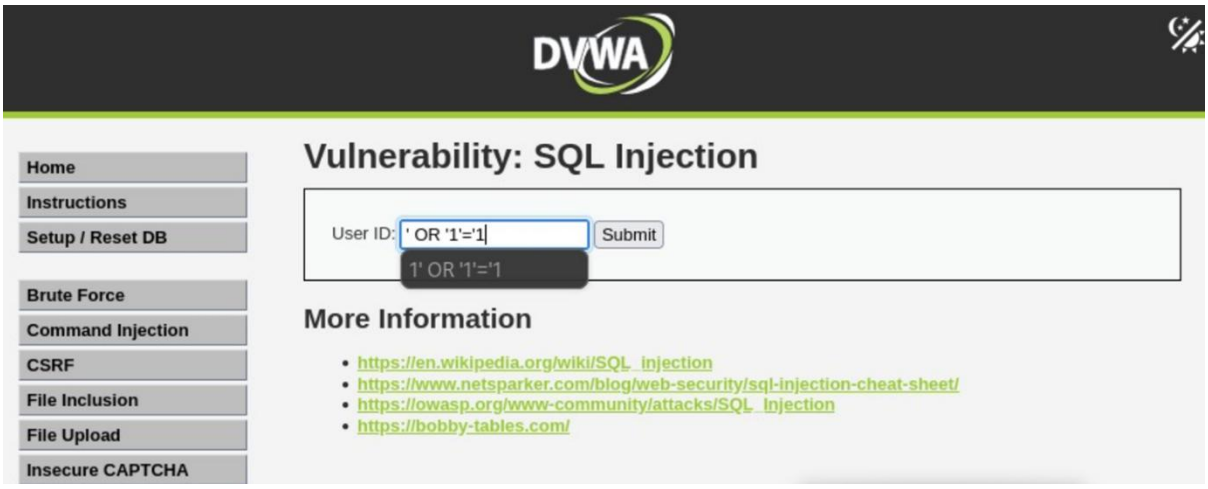


Figure 22. SQLI 6

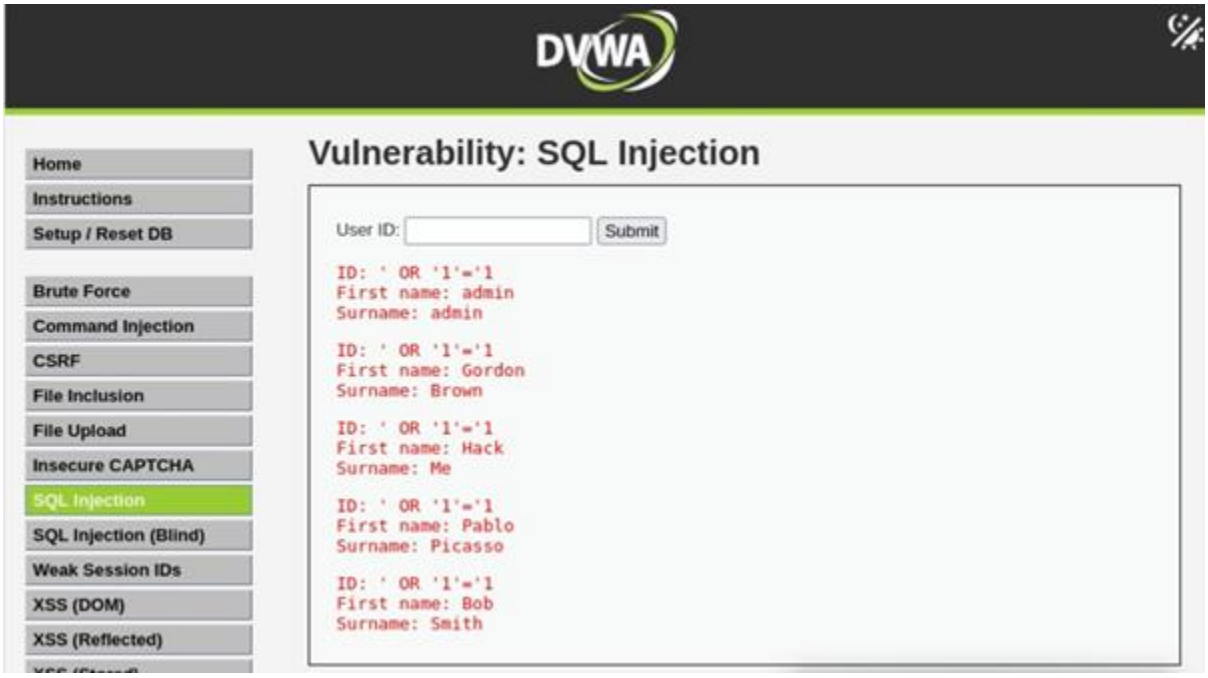


Figure 23. SQLI 7

the application merged our injected query with the original SELECT statement and returned every record from the users table. As a result, all usernames and their password hashes are displayed on the page, clearly demonstrating that unsanitized input allowed unauthorized retrieval of sensitive credentials.

Lab Defense Analysis

Current Security Status:
The testing environment demonstrated typical vulnerabilities found in unprotected web applications. DVWA intentionally lacks proper input validation and parameterized queries, making it vulnerable to SQL injection attacks.[5]

Observed Defensive Gaps:

- No input sanitization or validation
- Direct SQL query construction using user input
- Detailed error messages revealing system information
- No Web Application Firewall (WAF) protection
- Missing prepared statement implementation

Suggested Defense Improvements

Based on the simulation results, the following security controls should be implemented in MediCloud's web applications:

1. Parameterized Queries:

- Implement prepared statements for all database interactions
- Separate SQL code from user data input
- Use placeholder parameters for dynamic values[2]

2. Input Validation:

- Implement whitelist-based input validation
- Sanitize all user inputs before database queries
- Reject inputs containing SQL special characters[3]

3. Web Application Firewall:

- Deploy WAF to filter malicious HTTP requests
- Configure rules to detect SQL injection patterns
- Enable real-time blocking of suspicious activities[6]

4. Database Security:

- Use least privilege principle for database accounts
- Avoid connecting with administrative database privileges
- Implement database activity monitoring[7]

5. Error Handling:

- Implement generic error messages for users
- Log detailed errors for administrative review
- Avoid exposing database structure in error messages[8]

Ransomware attack

Attack methodology

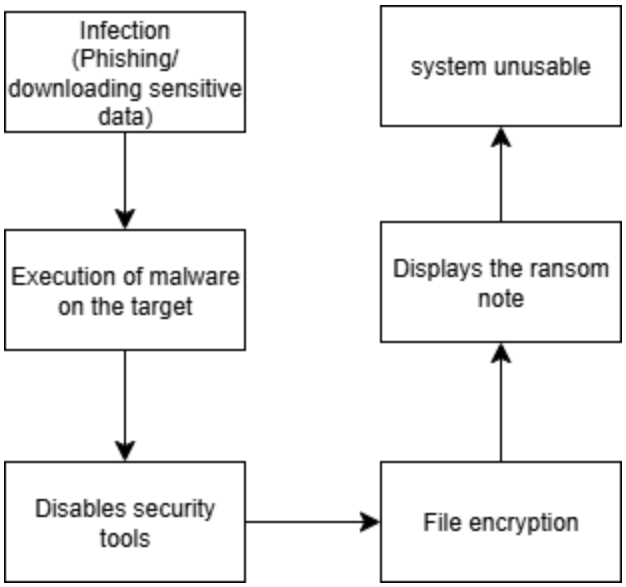


Figure 24. Ransome flow

A ransomware attack follows a multi-stage process designed to infiltrate, persist, spread, and ultimately encrypt data for extortion.

It typically begins with Initial Access, where attackers gain a foothold on a victim's system. Common methods include phishing emails with malicious attachments, exploiting vulnerabilities in internet-facing software like Remote Desktop Protocol (RDP), or using compromised credentials. Once the initial device is infected, the ransomware payload is delivered and executed.

The next phase involves Execution and Persistence. The malware ensures it survives system reboots by creating scheduled tasks, modifying registry keys, or installing itself as a service. To operate unimpeded, it often attempts to disable security defenses—such as antivirus software and Windows Defender—and deletes or encrypts system backup files and Volume Shadow Copies to prevent easy recovery.

Before launching the encryption, the ransomware may perform Discovery and Lateral Movement. It scouts the network to understand its structure, identifies valuable targets like file servers and databases, and uses harvested credentials to spread to other computers, maximizing the impact of the attack.

The core of the attack is the Data Encryption phase. The ransomware uses a strong, fast encryption algorithm (like AES) to lock files. To make decryption impossible without the attacker's help, it encrypts the AES key with a separate, asymmetric key (like RSA) that only the attacker holds. As it encrypts, it appends a new file extension (e.g., .locked, .crypted) and often deletes the original files. A ransom note is then dropped, explaining the situation and demanding payment.

Finally, the Ransom and Extortion phase begins. The note instructs the victim to contact the

attackers, usually through a Tor hidden service website to maintain anonymity. Modern attacks often employ "double extortion," where the attackers not only encrypt the data but also threaten to publish stolen sensitive information publicly if the ransom is not paid, adding significant pressure on the victim to comply.

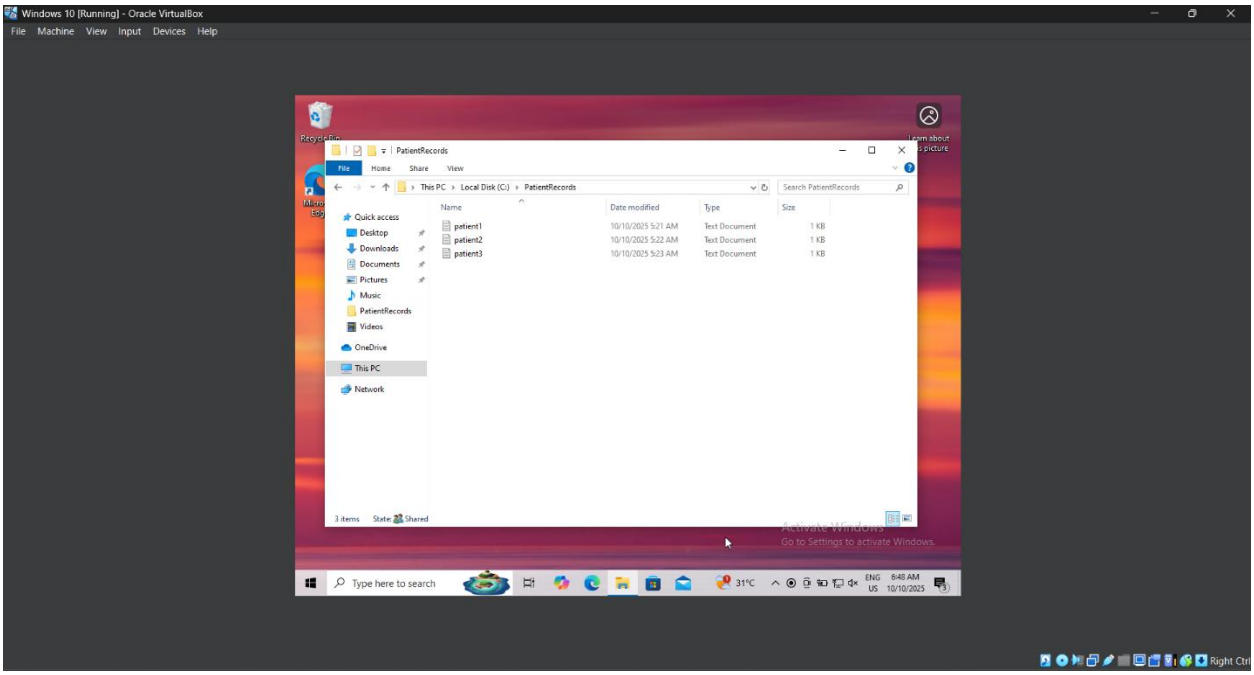


Figure 25. Ransomware 1

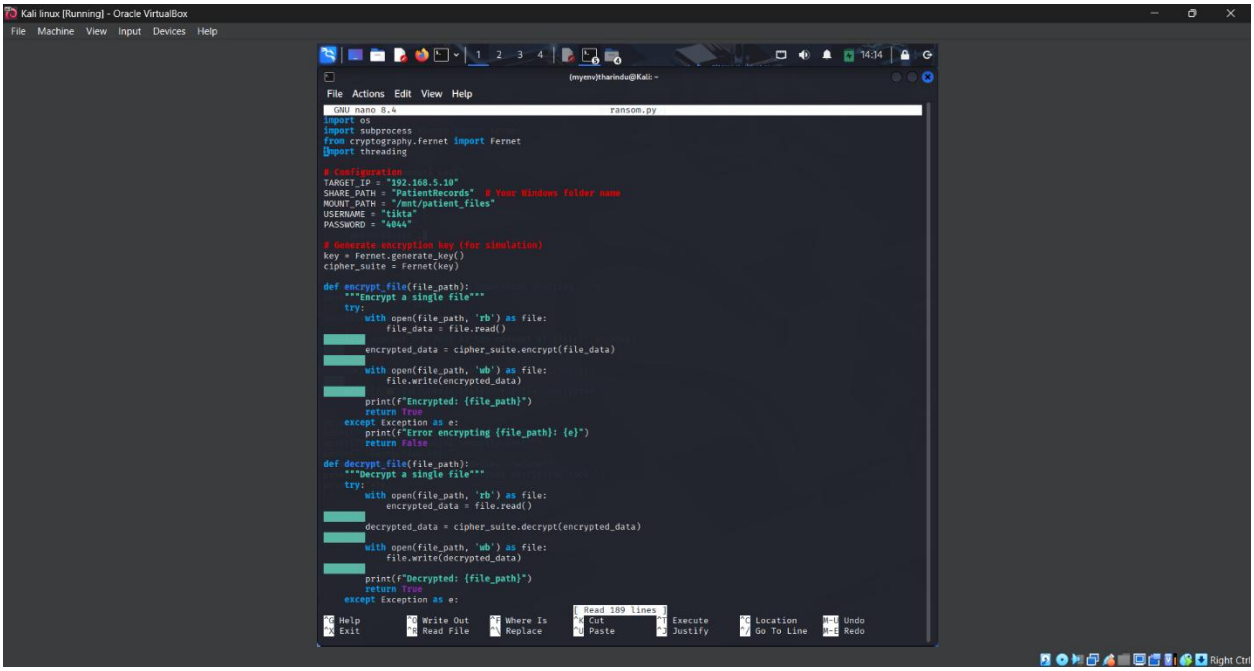


Figure 26. Ransomware 2

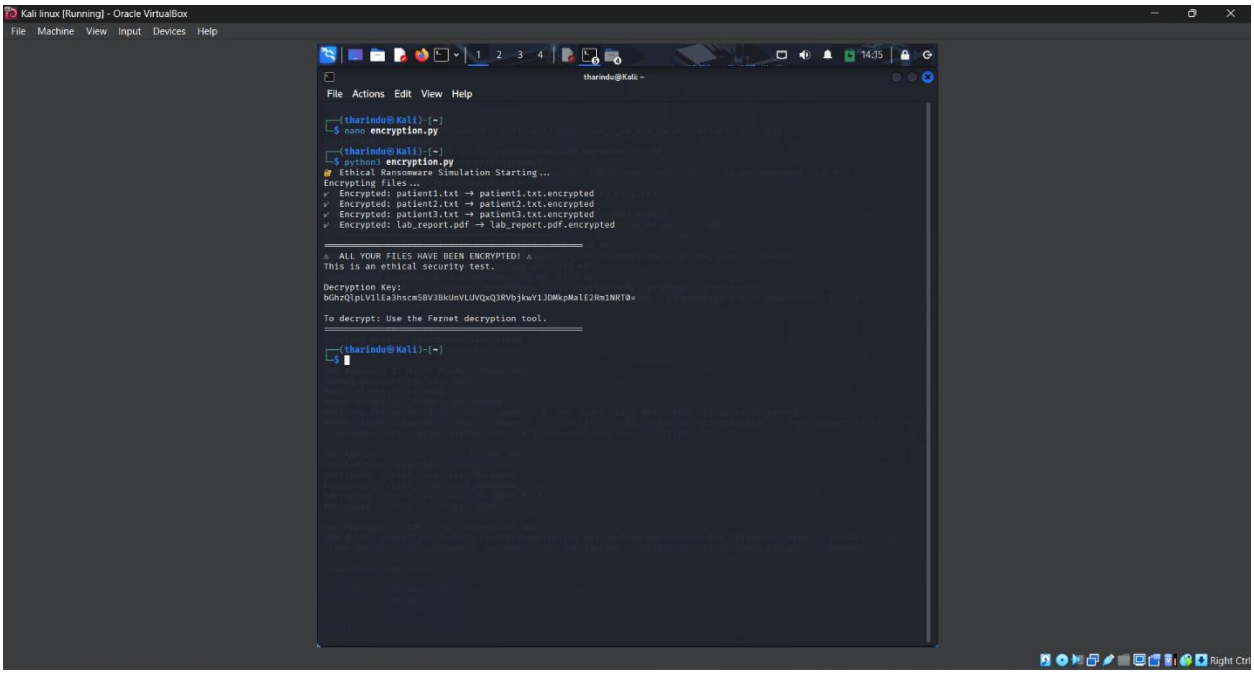


Figure 27. Ransomware 3

Defensive Strategies

Based on the ransomware simulation, the following security controls should be implemented:

1. Endpoint Detection and Response (EDR):

- Deploy EDR solutions on all workstations and servers
- Implement behavioral analysis to detect encryption patterns
- Enable real-time blocking of ransomware activities

2. Backup and Recovery Strategy:

- Implement the 3-2-1 backup rule (3 copies, 2 media types, 1 offsite)
- Conduct regular backup restoration drills
- Maintain isolated, air-gapped backups

3. Application Whitelisting:

- Implement application control policies
- Allow only authorized executables to run
- Block unauthorized encryption tools

4. Least Privilege Access:

- Implement principle of least privilege for user accounts
- Restrict writing permissions to essential directories only

- Use application sandboxing where possible

INCIDENCE RESPONSE PLAN

Incident Response Team – Roles/ Responsibilities

Role	Primary Responsibilities	Assigned to
Incident commander	Overall leadership, decision-making, and resource allocation	Admin
Security analyst	Digital forensics, malware analysis, log investigation	Management (blue team)
IT lead	System containment, restoration, and backup recovery	Admin
Network engineer	Network isolation, firewall rules, traffic monitoring	Network team (blue team)
Legal officer	Regulatory reporting (HIPAA), legal obligations	Legal department
Communication lead	Internal/external communications, patient notifications	Admin

Attack-Specific Response Procedures

SQL Injection Attack Response

Detection & Analysis
An SQL Injection incident is typically detected through a combination of automated Web Application Firewall (WAF) alerts flagging malicious SQL patterns and database servers logging unusual error messages or a high volume of complex query requests. Upon alert, the Security Analyst will conduct a forensic review of the web server logs to identify the exact malicious payloads used and determine which database tables or patient data sets may have been accessed, modified, or exfiltrated.

Containment
Immediate containment involves the Network Engineer blocking the attacker's source IP address at the perimeter firewall to halt further exploitation. Simultaneously, the IT Operations Lead will temporarily disable the specific web form or application function that is vulnerable. For long-term containment, the team will implement custom WAF rules designed to filter out the specific

SQL injection patterns identified and developers will be tasked with patching the vulnerable application code.

Eradication & Recovery
Eradication requires a thorough investigation to find and remove any database backdoors, such as unauthorized stored procedures or new user accounts, that the attacker may have created. Recovery involves restoring the affected database tables from known clean backups to ensure data integrity. To prevent recurrence, the development team must refactor the application code to implement secure programming practices, primarily parameterized queries, which separate SQL code from data.

Ransomware Attack Response

Detection & Analysis
The primary detection of a Ransomware attack often comes from Endpoint Detection and Response (EDR) tools alerting on mass file encryption activities in real-time, coupled with multiple user reports confirming they cannot access their files and see ransom notes. The Security Analyst will then work to identify 'patient zero'—the first infected machine—determine the specific ransomware variant to understand its capabilities, and map the full extent of the encryption spread across network shares and connected systems.

Containment
The immediate containment action is to disconnect the infected systems from the network, including disabling Wi-Fi and VLAN access, to prevent the ransomware from spreading to other devices. For long-term containment, the Network Engineer may need to isolate entire network segments and implement firewall rules to block communication with the ransomware's command-and-control (C2) domains, effectively starving the malware of instructions.

Eradication & Recovery
Eradication involves using the EDR tools to quarantine and remove all ransomware executable files and associated artifacts from the infected systems. Recovery is a critical phase where the IT Operations Lead restores encrypted data and systems from offline, verified backups. It is paramount that every system is thoroughly scanned and verified to be clean before it is reconnected to the network to avoid a recurrence of the encryption event.

Phishing Attack Response

Detection & Analysis
A Phishing incident is usually detected through a combination of user reports to the IT helpdesk, email security gateway filters flagging malicious emails, and SIEM alerts showing anomalous login patterns or data transfer activities from compromised accounts. The Security Analyst will analyze the phishing email's headers to trace its origin, identify all user accounts that interacted with the email, and check logs for any signs of successful credential theft or subsequent data exfiltration.

Containment
The immediate containment step is to disable any user accounts that have been confirmed as compromised, and to revoke all active session tokens associated with those accounts to eject any active attackers. For long-term containment, the IT Operations Lead will force a password reset for all potentially affected users and the Network Engineer will block the sender's domain and IP addresses at the email gateway and firewall level.

Eradication & Recovery
Eradication involves the systematic removal of the malicious phishing email from all user mailboxes across the organization to prevent further victimization. All workstations that were used to click on the phishing link must be scanned for any malware that may have been deployed. As a key recovery and hardening step, Multi-Factor Authentication (MFA) should be enforced for all privileged accounts to mitigate the impact of any future credential theft.

DDoS Attack Response

Detection & Analysis
A Distributed Denial-of-Service (DDoS) attack is detected through network monitoring alerts indicating a massive, anomalous spike in inbound traffic, coupled with service unavailability reports from users unable to access critical applications like the patient portal. The Security and Network Engineers will work together to analyze the traffic and identify the attack type—whether it is a volumetric flood, a protocol attack, or a more sophisticated application-layer attack—and determine the source IP ranges.

Containment
The immediate containment action is to activate the pre-contracted cloud DDoS protection service, which will reroute all network traffic through their scrubbing centers to filter out malicious packets while allowing legitimate traffic to pass through to MediCloud's servers. For long-term containment, the Network Engineer will implement rate-limiting rules on firewalls and routers to blunt the effectiveness of similar future attacks.

Eradication & Recovery
Eradication involves working with the Internet Service Provider (ISP) to block the attack traffic at the network edge, upstream from MediCloud's infrastructure. Recovery is a careful process of gradually restoring the normal traffic flow by de-escalating the DDoS mitigation measures while continuously monitoring network traffic for any signs of a secondary or persistent attack.

MITM Attack on IoT Devices

Detection & Analysis
A Man-in-the-Middle (MITM) attack on IoT devices is primarily detected by the Network Intrusion Detection System (NIDS), which alerts on unauthorized ARP traffic or other signs of network manipulation like rogue access points. Clinicians may also report anomalies in medical

device readings or communication failures. The Security Analyst will then analyze network traffic patterns to identify the point of interception and verify the integrity of the affected medical devices.

Containment
Immediate containment requires physically or logically isolating the affected IoT devices, such as a patient monitor or infusion pump, from the network to prevent the ongoing interception of sensitive patient vitals. The Network Engineer will also work to identify and block any unauthorized network bridges or rogue devices facilitating the attack. For long-term containment, the IoT network will be further segmented with stricter firewall policies, and certificate-based authentication will be enforced for all device communications.

Eradication & Recovery
Eradication involves resetting the compromised IoT devices to their factory settings to remove any malicious configurations or software that may have been injected. Recovery requires re-establishing encrypted communication channels, such as TLS, between the IoT devices and their central management servers. Finally, the IT Operations Lead will ensure all device firmware and security certificates are updated to the latest, most secure versions.

Communication Protocol

Incident severity	Internal notification	External notification	Timeline
Critical (Ransomware, data breach)	IRT immediately, Executives within 30 mins	Patients, Regulators within 72 hours per HIPAA	Immediate
High (DDoS, phishing)	IRT immediately, Department heads within 2 hours	ISP, Law Enforcement if needed	2 – 24 hours
Medium (Minor breaches)	IRT within 4 hours	None required	4 – 1 week

Preparation Activities

Technical Preparation
The foundation of effective incident response is robust preparation. This includes regularly testing and verifying the integrity of data backups through recovery drills, ensuring that systems can be restored within required timeframes. The Security team continuously tunes SIEM rules and validates alerts to reduce false positives and ensure genuine threats are not missed. Network segmentation is periodically validated to ensure that isolation protocols will function as intended during a crisis, and all Endpoint Detection and Response (EDR) signatures are kept up-to-date to recognize the latest malware variants.

Training & Awareness
To maintain a state of readiness, the Incident Response Team participates in quarterly tabletop

exercises that simulate realistic attack scenarios, testing the procedures and decision-making outlined in this plan. Furthermore, all staff undergo regular phishing simulation exercises to heighten vigilance and reinforce their role as the first line of defense. The Incident Response Plan itself is a living document, reviewed and updated annually or after any significant security incident to incorporate lessons learned.

Post-Incident Activities

For Every Incident
Following the resolution of any security incident, a formal documentation process is initiated to capture the complete timeline, actions taken, and lessons learned. This documentation must be completed within five business days while details are still fresh. A "Lessons Learned" session is then conducted with all stakeholders to openly discuss what worked well, what did not, and how the response can be improved. The outputs from this session are used to update this Incident Response Plan and to drive tangible improvements in security controls, thereby strengthening MediCloud's overall security posture against future attacks.

SECURITY CONTROLS & MITIGATION PLAN

SQL Injection Attack

- Technical Control: Web Application Firewall (WAF)

A WAF provides an immediate defensive layer by inspecting incoming HTTP/S traffic and blocking requests containing malicious SQL patterns before they reach the web application. It acts as a virtual patch while long-term code fixes are developed (Idris et al., 2021).

- Organizational Policy: Secure Coding Standards & Training

This addresses the root cause by ensuring developers write secure code. Training in parameterized queries and input validation prevents SQL injection vulnerabilities from being introduced during development (Bruno, 1997).

MITM Attack

- Technical Control: Encryption-in-Transit (TLS 1.3+)

Enforcing strong TLS encryption ensures that any data intercepted between IoT devices and the central server is unreadable to the attacker. This is critical for protecting the integrity and confidentiality of patient vital signs (Eastlake, 2011).

- Organizational Policy: Network Security Policy for Medical Devices

A formal policy mandates encryption and network segmentation for all new medical devices procured, ensuring security is a non-negotiable requirement and preventing the introduction of vulnerable devices.

Ransomware Attack

- Technical Control: Endpoint Detection and Response (EDR)

EDR solutions use behavioral analysis to detect and block the encryption activities characteristic of ransomware in real-time, far surpassing the capabilities of traditional antivirus software (Ghasemigol et al., 2010).

- Organizational Policy: Least Privilege & 3-2-1 Backup Rule

The principle of least privilege limits the spread of ransomware by restricting user permissions. The 3-2-1 backup rule (3 copies, 2 media types, 1 offsite) ensures data can be recovered without paying the ransom, guaranteeing business continuity (Alves et al., 2025).

Phishing Attack

- Technical Control: Multi-Factor Authentication (MFA)

MFA neutralizes the risk of stolen credentials obtained via phishing. Even if a user reveals their password, the attacker cannot authenticate without the second factor (Grassi et al., 2017).

- Organizational Policy: Regular Security Awareness Training

Continuous training transforms employees into a proactive human firewall by teaching them to identify, avoid, and report phishing attempts, significantly reducing the attack success rate (Pfleeger & Caputo, 2012).

DDoS Attack

- Technical Control: Next-Generation Firewall (NGFW) with DDoS Protection

A NGFW with integrated DDoS mitigation can identify and block malicious flood traffic based on advanced heuristics and threat intelligence, preventing service disruption and ensuring availability (Zargar et al., 2013).

- Organizational Policy: DDoS-Specific Incident Response Plan

A dedicated plan ensures a swift, coordinated response to minimize downtime. It clearly defines roles, communication protocols, and escalation procedures to DDoS mitigation service providers (Cichonski et al., n.d.).

Mitigation Plan

Phase	Timeline	Key actions	Scalability Justification
Immediate Foundation	0-30 Days	1. Deploy Cloud WAF & DDoS Protection 2. Enable MFA for all administrative accounts 3. Verify and test offline backup integrity	Cloud-based services (WAF, DDoS) offer on-demand scalability. MFA licenses can be added per user.
Core Infrastructure	1-6 Months	1. Enterprise-wide EDR rollout 2. Enforce TLS 1.3+ across all services 3. Initiate mandatory security awareness program	Centralized EDR management scales to new endpoints. Training platforms are subscription-based.
Long-Term Resilience	6+ Months	1. Implement and enforce least privilege access 2. Integrate static code analysis into SDLC 3. Conduct bi-annual incident response drills Cloud-based services (WAF, DDoS) offer on-demand scalability. MFA licenses can be added per user.	Automated policy enforcement and CI/CD integration ensure security scales with development and organizational growth.

PYTHON SCRIPT

This script demonstrates AES-256-CBC encryption, which is crucial for protecting sensitive patient data at MediCloud Health. The process begins by generating a cryptographically secure random key and initialization vector (IV). The key acts as the main secret for both encryption and decryption, while the IV ensures that identical plaintexts produce different ciphertexts, enhancing security.

When a user enters patient data, the script first converts it to bytes and applies PKCS7 padding. This padding is necessary because AES encrypts data in fixed 16-byte blocks, and the padding ensures the data length is a perfect multiple of this block size. The script then initializes the AES-256-CBC cipher with the key and IV, encrypts the padded data, and produces binary ciphertext.

For decryption, the script reverses this process using the same key and IV. It decrypts the ciphertext back to padded data, then removes the PKCS7 padding to recover the original plaintext. Finally, it displays the original message, the encrypted version in Base64 format (for readability), and the successfully decrypted message, verifying that the process works correctly by comparing the original and decrypted texts.

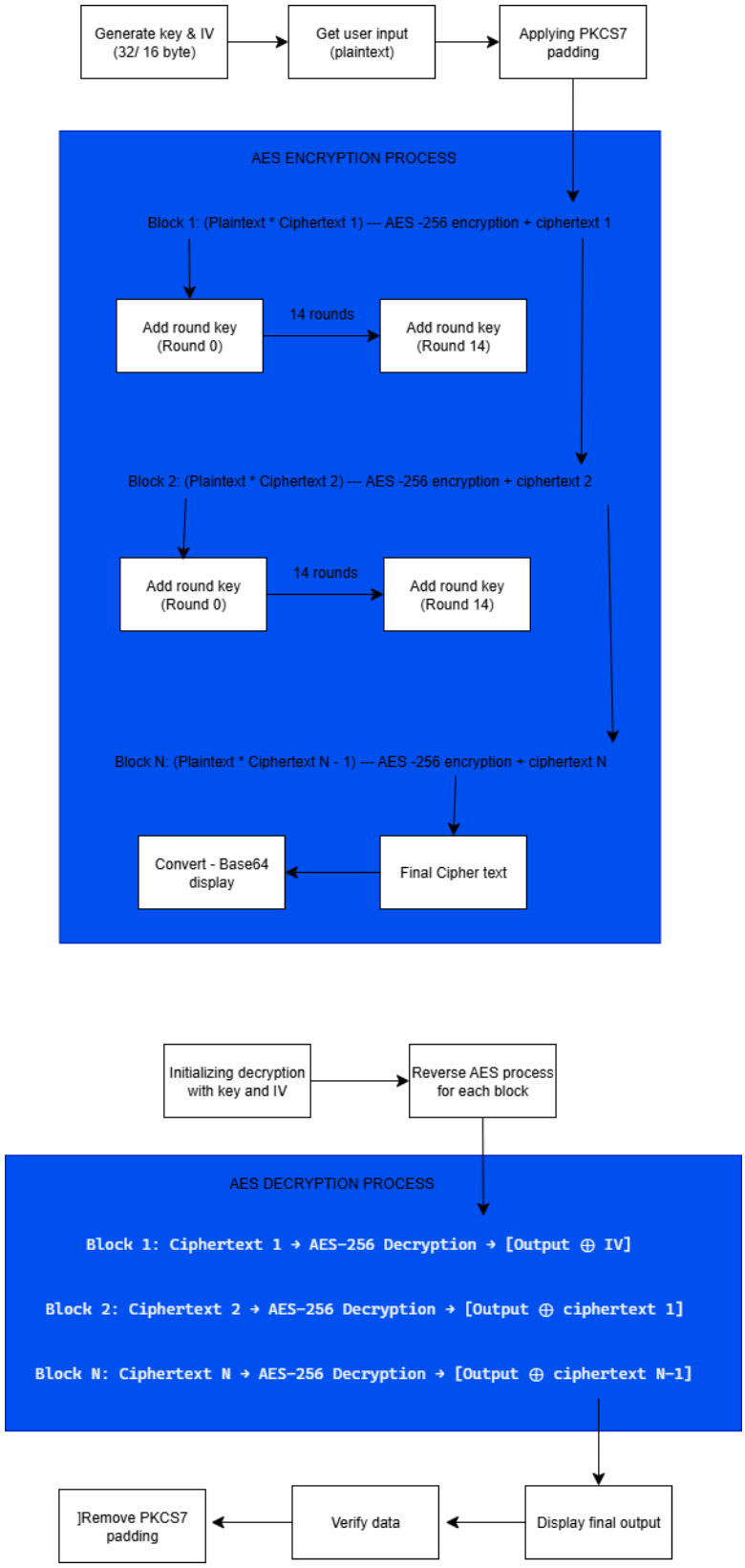


Figure 28. AES encryption flow

```python
# === IMPORT LIBRARIES ===
# These are the tools we need from the cryptography toolkit
from cryptography.hazmat.primitives.ciphers import Cipher, algorithms, modes
from cryptography.hazmat.primitives import padding
from cryptography.hazmat.backends import default_backend
import os
import base64

print("=== MediCloud Health Encryption Demo ===\n")

# === STEP 1: CREATE SECRET KEY AND IV ===
# Generate a random 32-byte (256-bit) key - THIS IS THE MAIN SECRET
key = os.urandom(32)
# Generate a random 16-byte (128-bit) Initialization Vector
iv = os.urandom(16)

print("✓ Generated secure 256-bit key and random IV")
print(f"Key size: {len(key)} bytes")
print(f"IV size: {len(iv)} bytes\n")

# === STEP 2: GET THE MESSAGE TO ENCRYPT ===
# Get input from user and convert to bytes (computers work with bytes, not text)
plaintext = input("Enter patient data to encrypt: ").encode('utf-8')
print(f"Original message: {plaintext.decode('utf-8')}")
print(f"Message size: {len(plaintext)} bytes\n")

# === STEP 3: APPLY PADDING ===
# AES works with 16-byte blocks. PKCS7 adds padding to make data fit perfectly.
padder = padding.PKCS7(128).padder()  # 128 bits = 16 bytes
padded_data = padder.update(plaintext) + padder.finalize()
print("✓ Applied PKCS7 padding")
print(f"Padded data size: {len(padded_data)} bytes\n")

# === STEP 4: ENCRYPT THE DATA ===
# Set up the AES-256-CBC encryption machine
cipher = Cipher(algorithms.AES(key), modes.CBC(iv), backend=default_backend())
encryptor = cipher.encryptor()
```

Figure 29. Python script 1

```python
encryptor = cipher.encryptor()
# Perform the actual encryption
ciphertext = encryptor.update(padded_data) + encryptor.finalize()

print("✓ Encryption completed")
print(f"Ciphertext size: {len(ciphertext)} bytes")

# === STEP 5: DECRYPT THE DATA ===
# Set up the decryption machine (using same key and IV)
decryptor = cipher.decryptor()
# Decrypt back to padded data
decrypted_padded_data = decryptor.update(ciphertext) + decryptor.finalize()

print("✓ Decryption completed")

# === STEP 6: REMOVE PADDING ===
# Strip off the padding to get original message back
unpadder = padding.PKCS7(128).unpadder()
decrypted_plaintext = unpadder.update(decrypted_padded_data) + unpadder.finalize()

print("✓ Padding removed\n")

# === STEP 7: DISPLAY RESULTS ===
# Convert binary ciphertext to Base64 for readable display
ciphertext_b64 = base64.b64encode(ciphertext).decode('utf-8')

print("=== RESULTS ===")
print(f"Original: '{plaintext.decode('utf-8')}'")
print(f"Encrypted: {ciphertext_b64}")
print(f"Decrypted: '{decrypted_plaintext.decode('utf-8')}'")

# Verification
if plaintext == decrypted_plaintext:
    print("✅ SUCCESS: Original and decrypted messages match!")
else:
    print("❌ ERROR: Decryption failed!")
```

Figure 30. Python script 2

```
PS C:\Users\Tharindu\OneDrive - Asia Pacific Institute of Information Technology\Degree 2nd year\CS - 1\Python Encryption> python medicloud-encrypt.py
=== MediCloud Health Encryption Demo ===

✓ Generated secure 256-bit key and random IV
Key size: 32 bytes
IV size: 16 bytes

Enter patient data to encrypt: Tharindu Ratnayake age 22
Original message: Tharindu Ratnayake age 22
Message size: 25 bytes

✓ Applied PKCS7 padding
Padded data size: 32 bytes

Key size: 32 bytes
IV size: 16 bytes

Enter patient data to encrypt: Tharindu Ratnayake age 22
Original message: Tharindu Ratnayake age 22
Message size: 25 bytes

✓ Applied PKCS7 padding
Padded data size: 32 bytes

✓ Encryption completed
Ciphertext size: 32 bytes
✓ Decryption completed
✓ Padding removed

Key size: 32 bytes
IV size: 16 bytes

Enter patient data to encrypt: Tharindu Ratnayake age 22
Original message: Tharindu Ratnayake age 22
Message size: 25 bytes

✓ Applied PKCS7 padding
Padded data size: 32 bytes

✓ Encryption completed
Ciphertext size: 32 bytes
```

Figure 31. Running python

```
✓ Encryption completed
Ciphertext size: 32 bytes
✓ Decryption completed
Padded data size: 32 bytes

✓ Encryption completed
Ciphertext size: 32 bytes
✓ Decryption completed
✓ Encryption completed
Ciphertext size: 32 bytes
✓ Decryption completed
✓ Padding removed

=== RESULTS ===
Original: 'Tharindu Ratnayake age 22'
✓ Decryption completed
✓ Padding removed

=== RESULTS ===
Original: 'Tharindu Ratnayake age 22'
Encrypted: LnzCIvgqURT6iwq7EGNHDlfO0oAsX2jrxuskTNgE47o=
✓ Padding removed

=== RESULTS ===
Original: 'Tharindu Ratnayake age 22'
Encrypted: LnzCIvgqURT6iwq7EGNHDlfO0oAsX2jrxuskTNgE47o=
Decrypted: 'Tharindu Ratnayake age 22'
=== RESULTS ===
Original: 'Tharindu Ratnayake age 22'
Encrypted: LnzCIvgqURT6iwq7EGNHDlfO0oAsX2jrxuskTNgE47o=
Decrypted: 'Tharindu Ratnayake age 22'
Encrypted: LnzCIvgqURT6iwq7EGNHDlfO0oAsX2jrxuskTNgE47o=
Decrypted: 'Tharindu Ratnayake age 22'
Decrypted: 'Tharindu Ratnayake age 22'
✅ SUCCESS: Original and decrypted messages match!
PS C:\Users\Tharindu\OneDrive - Asia Pacific Institute of Information Technology\Degree 2nd year\CS - 1\Python Encryption>
```

Figure 32. Encryption results

Explanation

Role of the Key

The 256-bit (32-byte) key serves as the fundamental secret in the encryption process. It is used for both encrypting and decrypting the data, meaning the same key must be available at both ends of the communication. The strength of the encryption relies entirely on the secrecy and randomness of this key; without it, recovering the original plaintext is computationally

infeasible. In the script, a secure key is generated using os.urandom (32).

Role of the Initialization Vector (IV)

The Initialization Vector (IV) is a 16-byte random value used to ensure that encrypting the same plaintext multiple times produces different ciphertexts each time. This prevents attackers from recognizing patterns in the encrypted data. The IV does not need to be secret but must be unpredictable and unique for each encryption operation. In this implementation, a new, random IV is generated for every encryption using os.urandom (16).

Explanation of Block Size

AES is a block cipher that processes data in fixed-size blocks of 128 bits (16 bytes). This means the encryption algorithm divides the plaintext into 16-byte chunks and encrypts each one individually. If the plaintext length is not a perfect multiple of 16 bytes, it must be padded before encryption.

Purpose of Padding (PKCS7)

PKCS7 padding is used to ensure the plaintext length is a multiple of the AES block size. It adds the necessary number of bytes to the end of the data, with each padding byte's value indicating the total number of bytes added. This scheme allows the decryption process to unambiguously identify and remove the padding after decryption, restoring the original message.

Importance of CBC Mode vs. Insecure Modes (like ECB)

CBC mode enhances security by chaining encryption blocks together. Each plaintext block is XORed with the previous ciphertext block before being encrypted. This means that identical plaintext blocks will result in different ciphertext blocks, obscuring patterns in the data.

REFERENCES

Ahad, A., Tahir, M., & Yau, K. L. A. (2019). 5G-based smart healthcare network: Architecture, taxonomy, challenges and future research directions. *IEEE Access*, *7*, 100747–100762. https://doi.org/10.1109/ACCESS.2019.2930628

Alves, R. S., Silva, J. P. B. da, Ribeiro Junior, L. A., & Nunes, R. R. (2025). Enhancing cybersecurity in the judiciary: Integrating additional controls into the CIS framework. *Computers & Security*, *157*, 104584. https://doi.org/10.1016/J.COSE.2025.104584

Anand, P., Singh, Y., Selwal, A., Alazab, M., Tanwar, S., & Kumar, N. (2020). IoT vulnerability assessment for sustainable computing: Threats, current solutions, and open challenges. *IEEE Access*, *8*, 168825–168853. https://doi.org/10.1109/ACCESS.2020.3022842

Bruno, L. (1997). Software & security. *Data Communications*, *26*(1), 662–665. https://doi.org/10.1007/S11623-012-0222-3/METRICS

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (n.d.). COMPUTER SECURITY INCIDENT HANDLING GUIDE *. *International Journal of Computer Research*, *20*(4).

Eastlake, D. (2011). *Transport Layer Security (TLS) Extensions: Extension Definitions*. https://doi.org/10.17487/RFC6066

Ghasemigol, M., Monsefi, R., & Sadoghi-Yazdi, H. (2010). Intrusion detection by ellipsoid boundary. *Journal of Network and Systems Management*, *18*(3), 265–282. https://doi.org/10.1007/S10922-010-9165-X

Grassi, P. A., Fenton, J. L., Newton, E. M., Perlner, R. A., Regenscheid, A. R., Burr, W. E., Richer, J. P., Lefkovitz, N. B., Danker, J. M., Choong, Y.-Y., Greene, K. K., & Theofanos, M. F. (2017). *Digital Identity Guidelines: Authentication and Lifecycle Management*. https://doi.org/10.6028/NIST.SP.800-63B

Hadi, H. J., Ahmad, N., Aziz, K., Cao, Y., & Alshara, M. A. (2024). Cost-Effective Resilience: A Comprehensive Survey and Tutorial on Assessing Open-Source Cybersecurity Tools for Multi-Tiered Defense. *IEEE Access*, *12*, 194053–194076. https://doi.org/10.1109/ACCESS.2024.3510533

Idris, M., Syarif, I., & Winarno, I. (2021). Development of Vulnerable Web Application Based on OWASP API Security Risks. *International Electronics Symposium 2021: Wireless Technologies and Intelligent Systems for Better Human Lives, IES 2021 - Proceedings*, 190–194. https://doi.org/10.1109/IES53407.2021.9593934

Lammle, T. (2003). *CCNA: Routing and Switching-Complete study guide second edition*. *1*, 6–8. https://books.google.com/books/about/CCNA_Routing_and_Switching_Complete_Stud.html?id=cRvqDAAAQBAJ

Lyon, G. Fyodor. (2008). *Nmap network scanning : official Nmap project guide to network discovery and security scanning*. 434. https://nmap.org/book/

Metasploit: The Penetration Tester's Guide - David Kennedy, Jim O'Gorman, Devon Kearns, Mati Aharoni - Google Books. (n.d.). Retrieved October 9, 2025, from https://books.google.lk/books?hl=en&lr=&id=TWKLBAAAQBAJ&oi=fnd&pg=PR2&dq=Kennedy,+D.,+O%27Gorman,+J.,+Kearns,+D.,+%26+Aharoni,+M.+(2011).+Metasploit:+The+Penetration+Tester%27s+Guide.&ots=mvNfCWqhFN&sig=XI_No9zURmzgYDHyB7Qp01SOTRo&redir_esc=y#v=onepage&q&f=false

Pfleeger, S. L., & Caputo, D. D. (2012). Leveraging behavioral science to mitigate cyber security risk. *Computers & Security*, *31*(4), 597–611. https://doi.org/10.1016/J.COSE.2011.12.010

Stuttard, D., & Pinto, M. (2011). *The Web Application Hacker's Handbook: Finding and*

Exploiting Security Flaws. *7*, 816. https://books.google.com/books/about/The_Web_Application_Hacker_s_Handbook.html?id=NSBHAAAAQBAJ

Sundholm, K. (2019). *HARDENING INDUSTRIAL NETWORK USING ISOLATED SEGMENTS*. http://www.theseus.fi/handle/10024/245173

Zargar, S. T., Joshi, J., & Tipper, D. (2013). A survey of defense mechanisms against distributed denial of service (DDOS) flooding attacks. *IEEE Communications Surveys and Tutorials*, *15*(4), 2046–2069. https://doi.org/10.1109/SURV.2013.031413.00127